# Cybersecurity Frameworks, Standards and Best Practices

Security Governance

MSc Cybersecurity

AY 2026-27

# WannaCry: the vulnerability was known

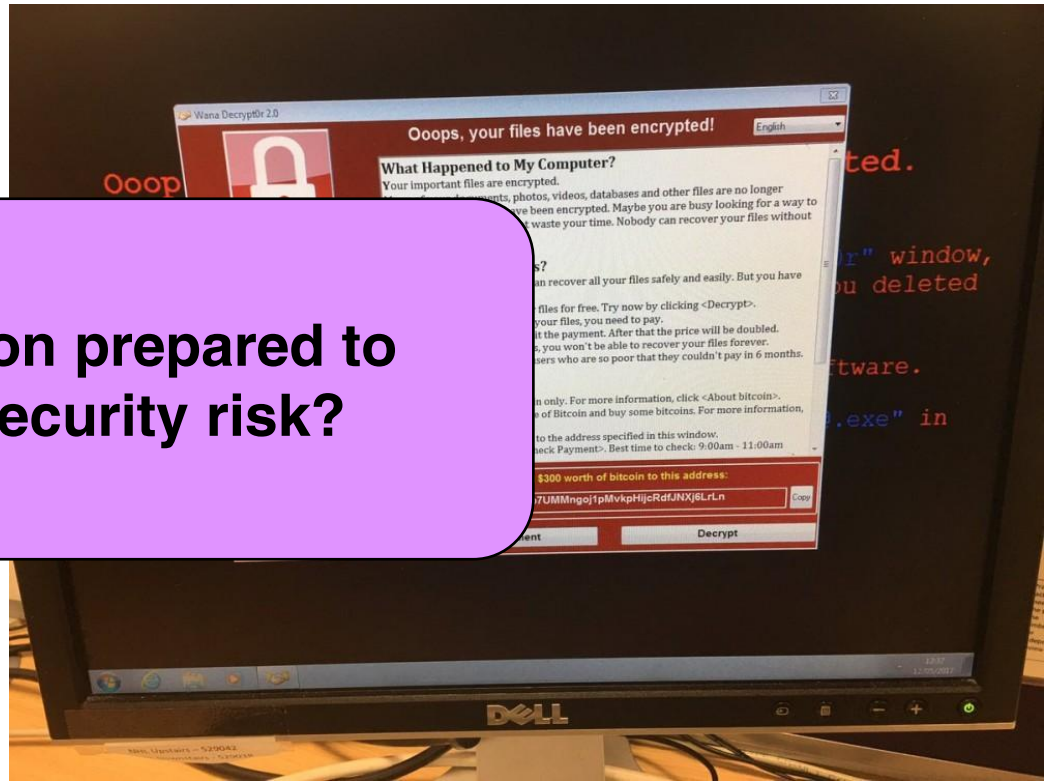
**May 2017**

- Hospitals across the UK suddenly find computers displaying a ransom message
- Patients are red
  and some medi

The malware exploitin

- The underlying Windows vulnerability had already been disclosed and Microsoft had released a security patch before the attack.

**Why wasn't the organization prepared to manage a known cybersecurity risk?**



# Outline

- **Definitions**
- **Frameworks**
  - *ISO 27001*
  - *NIST CSF*
  - *Italian NCF*
- **Implementation**
  - *ISO 27002*
  - *NIST SP 800-53*
  - *CIS Controls*
- **End of lesson**

# Definitions

**Cybersecurity framework**
A structured, ***risk-based*** approach that helps an organization organize, assess, and improve its cybersecurity activities and outcomes.

**Cybersecurity standard**
A formal set of requirements or specifications that an organization can implement and audit against to demonstrate and ***certify*** conformity.

**Best practice**
A procedure or method proven by ***research and experience*** to produce effective or optimal results, and suitable for widespread adoption.

- *In cybersecurity, a best practice is usually more actionable and less formal than a standard.*

A framework provides **guidance** for managing cybersecurity risk, a standard provides **specific requirements** that can be implemented and assessed, and a best practice provides **proven actions** to implement.

# Motivation: why we talk about framework and standards

Framework and standards provides a ***roadmap*** to assess, improve, and communicate security posture.

→ basically, they are the foundations to govern security

**Key aspects:**

- Standardized approaches
- Risk-based and adaptable
- Continuous improvement

**Examples**

- NIST Cybersecurity Framework (CSF)
- ISO/IEC 27001 & 27002
- CIS Controls
- COBIT
- ...

# History: from standards to frameworks and best practices

- 1990s → the UK BS 7799 (British information security standard) introduced one of the first **structured approaches** to information security management, later becoming the basis for ISO/IEC 17799 and then ISO/IEC 27001
- 1995 → BS 7799-1 was published as a **code of practice** for information security controls and guidance.
- 1998 → BS 7799-2 added the management system component and introduced the idea of a structured **Information Security Management System (ISMSs)**.
- 2000 → ISO/IEC 17799 adopted that earlier work **internationally**, and in 2005 ISO/IEC 27001 became the formal requirements standard for ISMSs, while ISO/IEC 27002 evolved as the companion guidance on controls.
- **Best practices** emerged as proven procedures and controls that organizations could apply even before formal certification or framework adoption.
  - NIST defines a … roduce optimal results and sui…
  - Examples inclu… osure, access control hygiene, and u… d in standards and referenced by …

National Institute of Standards and Technology (**NIST**) is an US agency founded in 1901 that develops scientific, technological, and measurement standards to promote innovation and industrial safety.

# History: from standards to frameworks and best practices

- 2013 → Executive Order 13636 (Barack Obama) directed **NIST** to work with stakeholders to develop a voluntary framework for reducing cyber risk to critical infrastructure.
- 2014 → NIST issued Version 1.0 of the Framework for Improving Critical Infrastructure Cybersecurity, developed with extensive private-sector input.
  - The Framework was explicitly designed as **voluntary guidance** based on existing standards, guidelines, and practices, which made it flexible and broadly adoptable beyond critical infrastructure.
- 2014 → The Cybersecurity Enhancement Act reinforced and formalized NIST's role in cybersecurity framework development.
  - The Act updated NIST's role to support the development of "a **voluntary**, **consensus-based**, i**ndustry-led** set of standards, guidelines, best practices, methodologies, procedures, and processes" to **reduce cyber risk** to critical infrastructure.
  - The Act is important because it explicitly connected three concepts that are still central today: standards, frameworks, and best practices.
  - Th… …gal ba…
- 2018 → … …elf-assess…

The NIST Cybersecurity Framework (**CSF**) is a voluntary set of guidelines, best practices, and standards created by NIST to help organizations manage and reduce cybersecurity risks.

Recognized world wide as the basis of security governance.

# Organization of different frameworks (shortlist)

- **DORA** — Digital Operational Resilience Act, financial sector
- **NIS2** — EU cybersecurity directive
- **FISMA** — U.S. federal information security
- **FedRAMP** — U.S. government cloud security
- **CMMC** — U.S. defense supply chain
- **HIPAA Security Rule** — U.S. healthcare
- **PCI DSS** — Payment-card security
- **IEC 62443** — Industrial/OT cybersecurity
- **TISAX** — Automotive industry
- **NERC CIP** — Electricity/energy sector
- **SWIFT Customer Security Programme (CSP)** — Financial messaging
- **Basel/BCBS cybersecurity principles** — Banking
- **EU Cybersecurity Act** — EU cybersecurity certification framework
- **National frameworks**
- **Italian National Cybersecurity Framework (Framework Nazionale per la Cybersecurity e la Data Protection)**
- **ACN cybersecurity frameworks/guidelines** — Italy
- **BSI IT-Grundschutz** — Germany
- **ANSSI cybersecurity guidance/frameworks** — France
- **NCSC Cyber Assessment Framework (CAF)** — UK
- **Essential Eight** — Australian Signals Directorate
- **Cyber Essentials / Cyber Essentials Plus** — UK
- **C5 (Cloud Computing Compliance Criteria Catalogue)** — Germany
- **Application / software security frameworks**
- **OWASP SAMM** — Software Assurance Maturity Model
- **OWASP Top 10** — Web application risks
- **OWASP API Security Top 10**
- **BSIMM** — Building Security In Maturity Model
- **NIST SSDF** — Secure Software Development Framework
- **SLSA** — Supply-chain Levels for Software Artifacts
- **NIST SP 800-218** — SSDF reference
- **Cloud security**
- **CSA Cloud Controls Matrix (CCM)**
- **CSA STAR**
- **ISO/IEC 27017**
- **NIST SP 800-144**
- **NIST SP 800-210**
- **FedRAMP**
- **C5**
- **Zero Trust**
- **NIST SP 800-207 — Zero Trust Architecture**
- **CISA Zero Trust Maturity Model**
- **DoD Zero Trust Reference Architecture**
- **Google BeyondCorp** — Zero-trust architecture model
- **Cybersecurity maturity models**
- **C2M2 — Cybersecurity Capability Maturity Model**
- **CMMC — Cybersecurity Maturity Model Certification**
- **COBIT 2019**
- **COBIT 5**
- **FAIR — Factor Analysis of Information Risk**
- **(DTEF)**
- **MITRE ATT&CK**
- **MITRE D3FEND**
- **MITRE Engage**
- **Cyber Kill Chain**
- **Diamond Model of Intrusion Analysis**
- **Unified Kill Chain**
- **CAPEC**
- **CWE**
- **STIX**
- **TAXII**
- **VERIS**
- **ATT&CK Navigator**
- **STRIDE**
- **PASTA**
- **Cyber Kill Chain**
- **MISP information-sharing model**
- **NIST CSF Tiers**
- **OWASP SAMM**
- **BSIMM**
- **CIS Implementation Groups**
- **SSE-CMM — Systems Security Engineering Capability Maturity Model**

Many more ...

# Organization of core frameworks

**Framework**: principles and practices for managing and improving security

- *ISO 27001, NIST CSF, Italian Cybersecurity Framework*

What should I account and how to organize security?

**Implementation**: Specific safeguards and measures to mitigate security risks

- *ISO 27002, NISP SP 800-53, CIS controls*

How to apply the strategy?

**Security Governance**

# More specifically...

| Layer | Main question | Instruments |
|---|---|---|
| Management system | How should information security be managed **continuously**? | ISO/IEC 27001 |
| Control guidance | Which information security controls can be **implemented**? | ISO/IEC 27002 |
| Risk framework | How can cybersecurity **risk** be organized and communicated? | NIST CSF, Italian NCF |
| Detailed controls | Which **safeguards** can be selected, tailored, and assessed? | NIST SP 800-53 |
| Practical safeguards | What should be **prioritized** and implemented first? | CIS Controls |

# Frameworks

ISO 27001

# ISO 27000 family

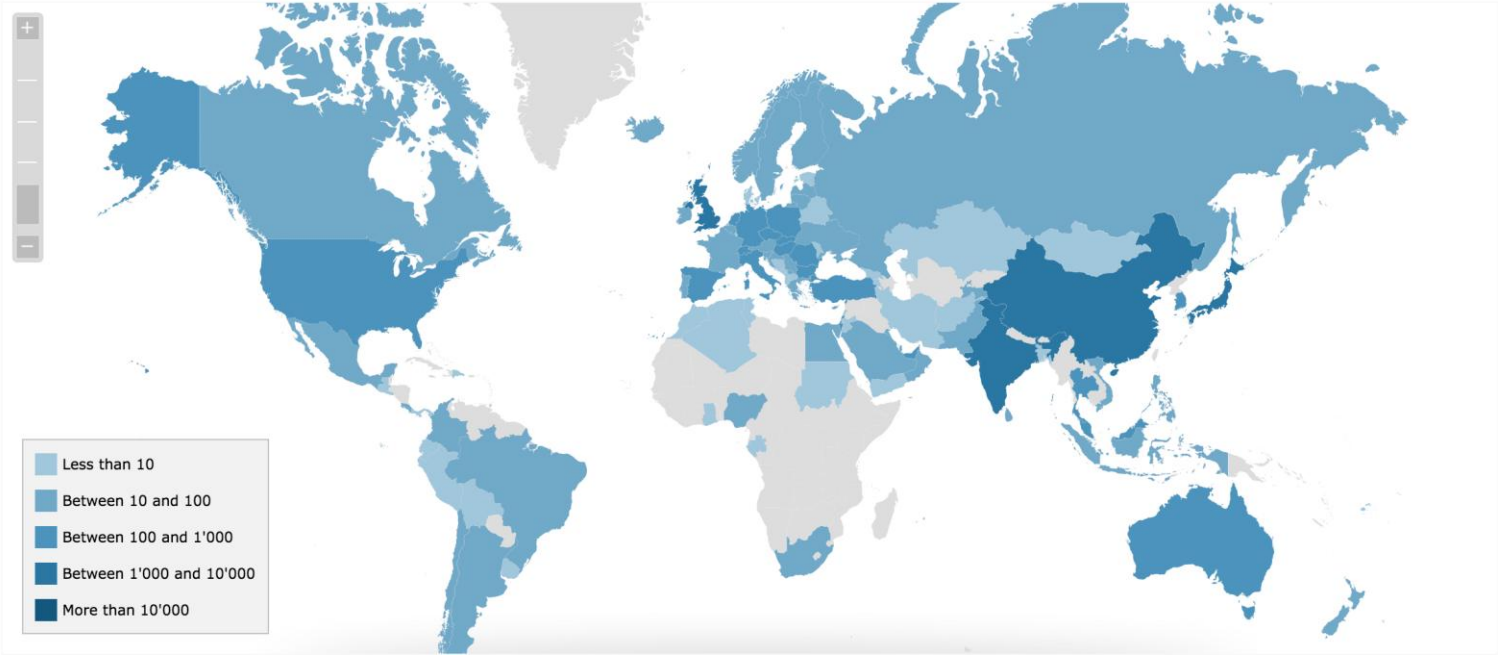
- ISO/IEC 27000 — Information security management systems — **Overview and vocabulary**
- **ISO/IEC 27001 — Information technology - Security Techniques - Information security management systems - Requirements**
- **ISO/IEC 27002 — Code of practice for information security management**
- ISO/IEC 27003 — Information security management system **implementation guidance**
- ISO/IEC 27004 — Information security management — Measurement
- ISO/IEC 27005 — Information security risk management
- ISO/IEC 27006 — Requirements for bodies providing audit and certification of information security management systems
- ISO/IEC 27007 — Guidelines for information security management systems auditing (focused on the management system)
- ISO/IEC TR 27008 — Guidance for auditors on ISMS controls (focused on the information security controls)
- ISO/IEC 27010 — Information security management for inter-sector and inter-organizational communications
- ISO/IEC 27011 — Information security management guidelines for telecommunications organizations based on ISO/IEC 27002
- ISO/IEC 27013 — Guideline on the integrated implementation of ISO/IEC 27001 and ISO/IEC 20000-1
- ISO/IEC 27014 — Information security governance.[4] Mahncke assessed this standard in the context of Australian e-health.[5]
- ISO/IEC TR 27015 — Information security management guidelines for financial services

# ISO 27000 family

- ISO/IEC 27018 — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors
- ISO/IEC 27031 — Guidelines for information and communication technology readiness for business continuity
- ISO/IEC 27032 — Guideline for cybersecurity
- ISO/IEC 27033-1 — Network security - Part 1: Overview and concepts
- ISO/IEC 27033-2 — Network security - Part 2: Guidelines for the design and implementation of network security
- ISO/IEC 27033-3 — Network security - Part 3: Reference networking scenarios - Threats, design techniques and control issues
- ISO/IEC 27033-4 — Network security - Part 4: Securing communications between networks using security gateways
- ISO/IEC 27033-5 — Network security - Part 5: Securing communications across networks using Virtual Private Networks (VPNs)
- ISO/IEC 27034-1 — Application security - Part 1: Guideline for application security
- ISO/IEC 27035 — Information security incident management
- ISO/IEC 27036-3 — Information security for supplier relationships - Part 3: Guidelines for information and communication technology supply chain security
- ISO/IEC 27037 — Guidelines for identification, collection, acquisition and preservation of digital evidence
- ISO 27799 — Information security management in health using ISO/IEC 27002. The purpose of ISO 27799 is to provide guidance to health organizations and other holders of personal health information on how to protect such information via implementation of ISO/IEC 27002.

# ISO 27001

It is the most international framework, recognized in over 60 countries.



# ISO 27001

- ISO/IEC 27001 is the world's best-known standard for **Information Security Management Systems (ISMS)**.
  - ISO/IEC 27001 follows a management system approach, meaning that security is treated as an ongoing organizational process rather than a one-time technical project.
- It specifies the requirements for establishing, implementing, maintaining, and continually improving an ISMS.

- Its purpose is to ensure that information security is managed systematically through governance, risk assessment, controls, monitoring, and improvement.
  - Organizations must define scope, assign responsibilities, assess and treat risks, measure performance, and continually improve the ISMS.

# ISO 27001: Deming Cycle

The **Deming Cycle**[1] is a continuous improvement method also known as PDCA.

It is used to test changes in a structured way.

- **Plan:** Identify a problem, define a goal, and decide how success will be measured.
- **Do:** Implement the change, usually on a small scale.
- **Check:** Review the results and compare them with the expected outcome.
- **Act:** Standardize the improvement if it works, or revise the plan and repeat the cycle.




1. W. Edwards Deming popularized and promoted it as a continuous-improvement method

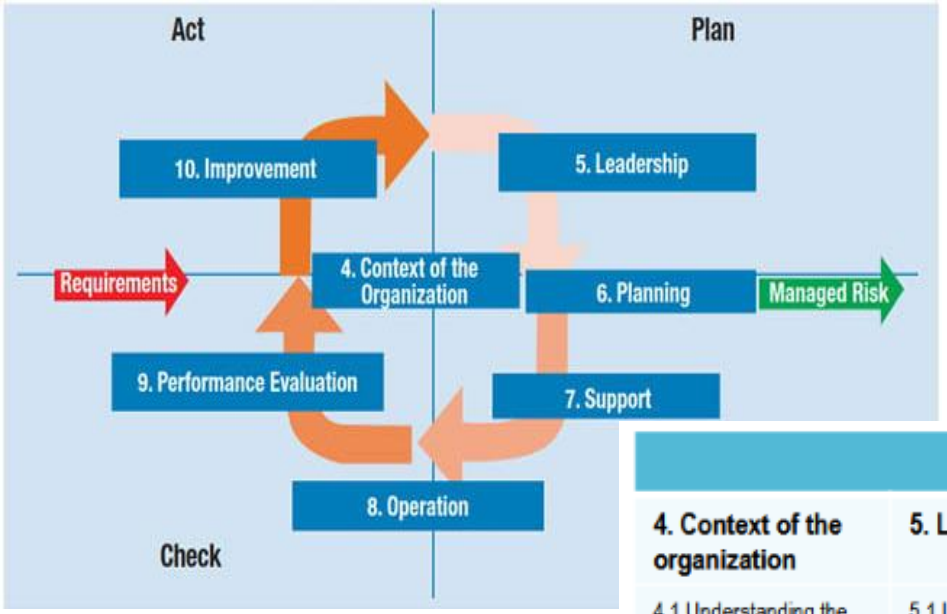
# ISO 27001: Clauses

ISO 27001 is structured into clauses that define the requirements for an Information Security Management System.

The mandatory requirements are in Clauses 4 to 10, while Clauses 1 to 3 provide context and definitions.

- **Clause 4 — Context of the organization:**
  understand the organization, interested parties, and ISMS scope.
- **Clause 5 — Leadership:**
  top management commitment, policy, roles, and responsibilities.
- **Clause 6 — Planning:**
  risk assessment, risk treatment, and security objectives.
- **Clause 7 — Support:**
  resources, competence, awareness, communication, and documented information.
- **Clause 8 — Operation:**
  implement and control the processes and risk treatment actions.
- **Clause 9 — Performance evaluation:**
  monitoring, measurement, internal audit, and management review.
- **Clause 10 — Improvement:**
  handle nonconformities and drive continual improvement.

# ISO 27001: Clauses




| PLAN | | | DO | | CHECK | ACT |
|---|---|---|---|---|---|---|
| **4. Context of the organization** | **5. Leadership** | **6. Planning** | **7. Support** | **8. Operation** | **9. Performance evaluation** | **10. Improvement** |
| 4.1 Understanding the organization and its context | 5.1 Leadership and commitment | 6.1 Actions to address risks and opportunities | 7.1 Resources | 8.1 Operational planning and control | 9.1 Monitoring, measurement, analysis and evaluation | 10.1 Nonconformity and corrective action |
| 4.2 Understanding the needs and expectations of interested parties | 5.2 Policy | 6.2 Information security objectives and planning to achieve them | 7.2 Competence | 8.2 Information security risk assessment | 9.2 Internal audit | 10.2 Continual improvement |
| 4.3 Determining the scope of the ISMS | 5.3 Organizational roles, responsibilities and authorities | | 7.3 Awareness | 8.3 Information security risk treatment | 9.3 Management review | |
| 4.4 Information Security Management System | | | 7.4 Communication | | | |
| | | | 7.5 Documented information | | | |

# ISO 27001: Clause 5




- **5.1 Leadership and commitment:** top management must actively support the ISMS, align it with business strategy, provide resources, and ensure it achieves its intended outcomes.
- **5.2 Policy:** the organization must define and communicate an information security policy that sets direction, supports objectives, and reflects commitment to compliance and continual improvement.
- **5.3 Organizational roles, responsibilities, and authorities:** roles must be assigned clearly so responsibilities are understood and reporting lines are effective.

*This clause makes information security a leadership responsibility, not only a technical activity.*

# ISO 27001: Clause 6




- **6.1 Actions to address risks and opportunities:** identify risks and opportunities related to the ISMS, then plan actions to reduce threats, prevent problems, and improve effectiveness.
- **6.2 Information security objectives and planning to achieve them:** set measurable security objectives and define who will do what, by when, and with which resources.
- **6.3 Planning of changes:** manage changes to the ISMS in a controlled way so that security is not weakened by poorly planned updates.
  - Manually
  - Automatically → self-adaptive systems

*This clause turns context and leadership into a practical plan for managing risk and improving security*

# ISO 27001: Clause 7




- **7.1 Resources:** provide the people, tools, budget, and infrastructure needed to run the ISMS effectively.
- **7.2 Competence:** ensure people performing security-related work have the necessary knowledge, training, and experience.
- **7.3 Awareness:** make sure staff understand the information security policy, their responsibilities, and the consequences of noncompliance.
- **7.4 Communication:** define what must be communicated, to whom, when, and through which channels.
- **7.5 Documented information:** create, maintain, and control documents and records needed to support and prove the ISMS works.

*This clause ensures the ISMS is supported by competent people, clear communication, and proper documentation.*

# ISO 27001: Clause 8




- **8.1 Operational planning and control:** plan and control operational processes so the ISMS is implemented as intended.
- **8.2 Information security risk assessment:** define a consistent method for identifying and evaluating information security risks.
- **8.3 Information security risk treatment:** select and implement controls or measures to treat unacceptable risks.

*This clause is where the ISMS becomes operational: risks are assessed, treatments are chosen, and controls are applied in practice.*

# ISO 27001: Clause 9




- **9.1 Monitoring, measurement, analysis, and evaluation:** track whether the ISMS is performing well using indicators, metrics, and analysis.
- **9.2 Internal audit:** regularly check whether the ISMS conforms to ISO 27001 and to the organization's own requirements.
- **9.3 Management review:** top management reviews the ISMS to confirm it remains suitable, effective, and aligned with business needs.

*This clause checks whether the ISMS is delivering results and whether leadership is using the evidence to steer improvements*

# ISO 27001: Clause 10



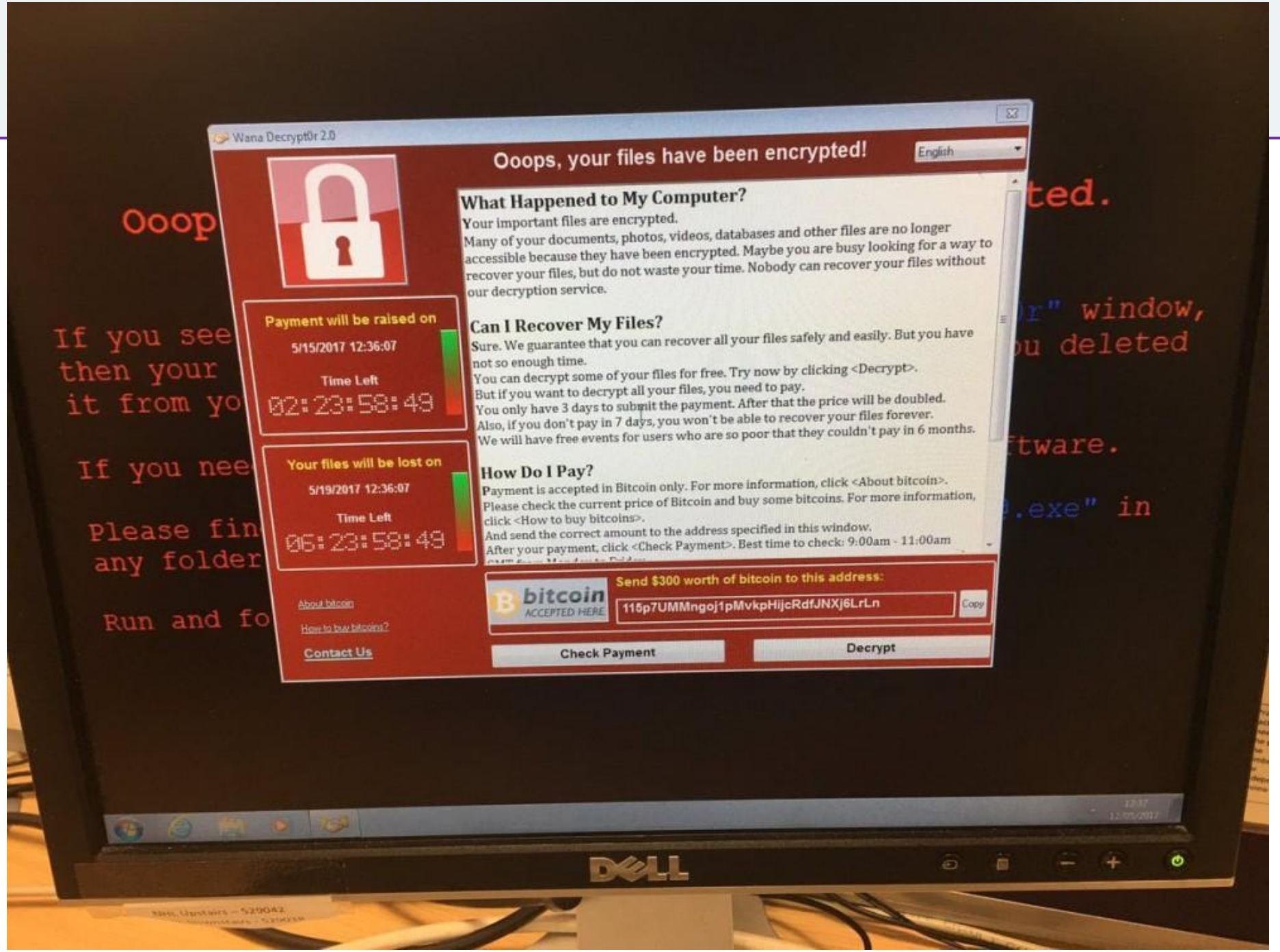
| PLAN | | | DO | | CHECK | ACT |
|---|---|---|---|---|---|---|
| **4. Context of the organization** | **5. Leadership** | **6. Planning** | **7. Support** | **8. Operation** | **9. Performance evaluation** | **10. Improvement** |
| 4.1 Understanding the organization and its context | 5.1 Leadership and commitment | 6.1 Actions to address risks and opportunities | 7.1 Resources | 8.1 Operational planning and control | 9.1 Monitoring, measurement, analysis and evaluation | 10.1 Nonconformity and corrective action |
| 4.2 Understanding the needs and expectations of interested parties | 5.2 Policy | 6.2 Information security objectives and planning to achieve them | 7.2 Competence | 8.2 Information security risk assessment | 9.2 Internal audit | 10.2 Continual improvement |
| 4.3 Determining the scope of the ISMS | 5.3 Organizational roles, responsibilities and authorities | | 7.3 Awareness | 8.3 Information security risk treatment | 9.3 Management review | |
| 4.4 Information Security Management System | | | 7.4 Communication | | | |
| | | | 7.5 Documented information | | | |

- **10.1 Nonconformity and corrective action:** investigate problems, fix root causes, and prevent recurrence.

- **10.2 Continual improvement:** keep strengthening the ISMS over time based on audits, incidents, measurements, and changing risks.

# Annex A and the Statement of Applicability

- ISO/IEC 27001 includes **Annex A**, which contains a reference set of information security controls.
- In the 2022 revision, Annex A contains **93 controls**, and organizations are expected to evaluate their applicability based on risk treatment decisions.
- These decisions are documented in the **Statement of Applicability (SoA)**, which links risks, selected controls, and justification for inclusion or exclusion
- A good SoA includes:
  - The Annex A control ID and name.
  - Whether the control is applicable or not.
  - A justification for inclusion or exclusion.
  - The implementation status of applicable controls.
  - Often, references SoA normally includes:
  - to policies, procedures, or evidence.


Wana Decrypt0r 2.0
Ooops, your files have been encrypted!
English
What Happened to My Computer?
Your important files are encrypted.
Many of your documents, photos, videos, databases and other files are no longer accessible because they have been encrypted. Maybe you are busy looking for a way to recover your files, but do not waste your time. Nobody can recover your files without our decryption service.
Can I Recover My Files?
Sure. We guarantee that you can recover all your files safely and easily. But you have not so enough time.
You can decrypt some of your files for free. Try now by clicking <Decrypt>.
But if you want to decrypt all your files, you need to pay.
You only have 3 days to submit the payment. After that the price will be doubled.
Also, if you don't pay in 7 days, you won't be able to recover your files forever.
We will have free events for users who are so poor that they couldn't pay in 6 months.
How Do I Pay?
Payment is accepted in Bitcoin only. For more information, click <About bitcoin>.
Please check the current price of Bitcoin and buy some bitcoins. For more information, click <How to buy bitcoins>.
And send the correct amount to the address specified in this window.
After your payment, click <Check Payment>. Best time to check: 9:00am - 11:00am
Payment will be raised on
5/15/2017 12:36:07
Time Left
02:23:58:49
Your files will be lost on
5/19/2017 12:36:07
Time Left
06:23:58:49
About bitcoin
How to buy bitcoins?
Contact Us
bitcoin
ACCEPTED HERE
Send $300 worth of bitcoin to this address:
115p7UMMngoj1pMvkpHijcRdfJNXj6LrLn
Copy
Check Payment
Decrypt
Ooop
ted.
If you see
then your
it from yo
r" window,
u deleted
If you nee
ftware.
Please fin
any folder
.exe" in
Run and fo
DELL

# Could ISO 27001 have prevented WannaCry?

**May 2017 — WannaCry is spreading.**

- You are the CISO of an organization with 2,000 Windows computers.
- Microsoft released the MS17-010 security patch **before the attack**.
- Your organization nevertheless has hundreds of unpatched machines.

- You implemented ISO 27001. So how did this still happen?
- If the organization had an ISO 27001 certificate, does that prove that every computer was patched?
- Which ISO 27001 activities should have helped prevent this situation?
  - Asset Inventory
  - Risk Assessment
  - Vulnerability Management
  - Monitoring
  - Incident Response
  - Security Awareness

# Frameworks

NIST CSF 2.0

# NIST CyberSecurity Framework (CSF)

It is the most used security governance framework[1]

- Focuses on using business drivers to guide cybersecurity activities and considering cybersecurity risks as part of the organization's risk management processes.
- NIST CSF was developed to improve cybersecurity risk management in critical infrastructures, but it can be used by organizations in any sector or community
- It provides a common organizing structure assembling standards, guidelines, and practices that are working effectively today

It is applicable to organizations relying on technology, whether their cybersecurity focus is primarily on

- information technology (IT),
- industrial control systems (ICS),
- cyber-physical systems (CPS),
- connected devices more generally, including the Internet of Things (IoT)

Consists of three parts:

1. Core
2. Implementation Tiers
3. Profiles

1. See slide on "History"

# NIST CSF Features

NIST CSF is technology neutral

- It remains effective and supports technical innovation
- It references a variety of existing standards, guidelines, and practices that evolve with technology

It provides a **common taxonomy** and **mechanism** for organizations to:

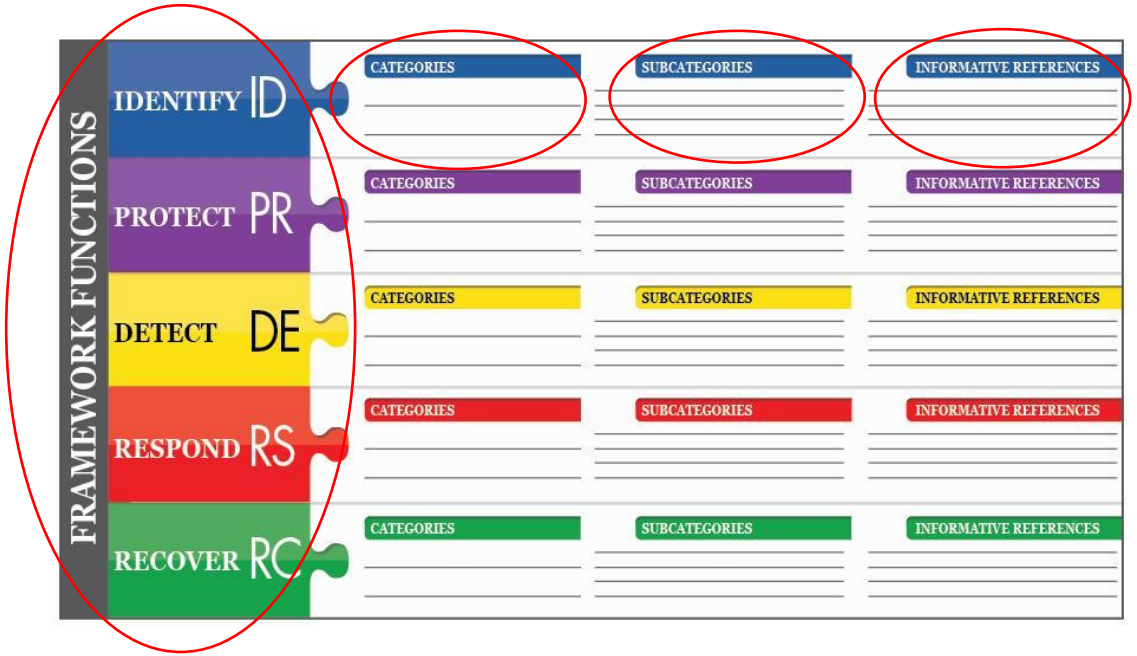
1. Describe their current cybersecurity posture;
2. Describe their target state for cybersecurity;
3. Identify and prioritize opportunities for improvement within the context of a continuous and repeatable process;
4. Assess progress toward the target state;
5. Communicate among internal and external stakeholders about cybersecurity risk.

# NIST CSF Core

- It provides a set of activities to achieve specific cybersecurity outcomes, and references examples of guidance to achieve those outcomes.
- The Core is not a checklist of actions to perform.
- It presents key cybersecurity outcomes identified by stakeholders as helpful in managing cybersecurity risk.

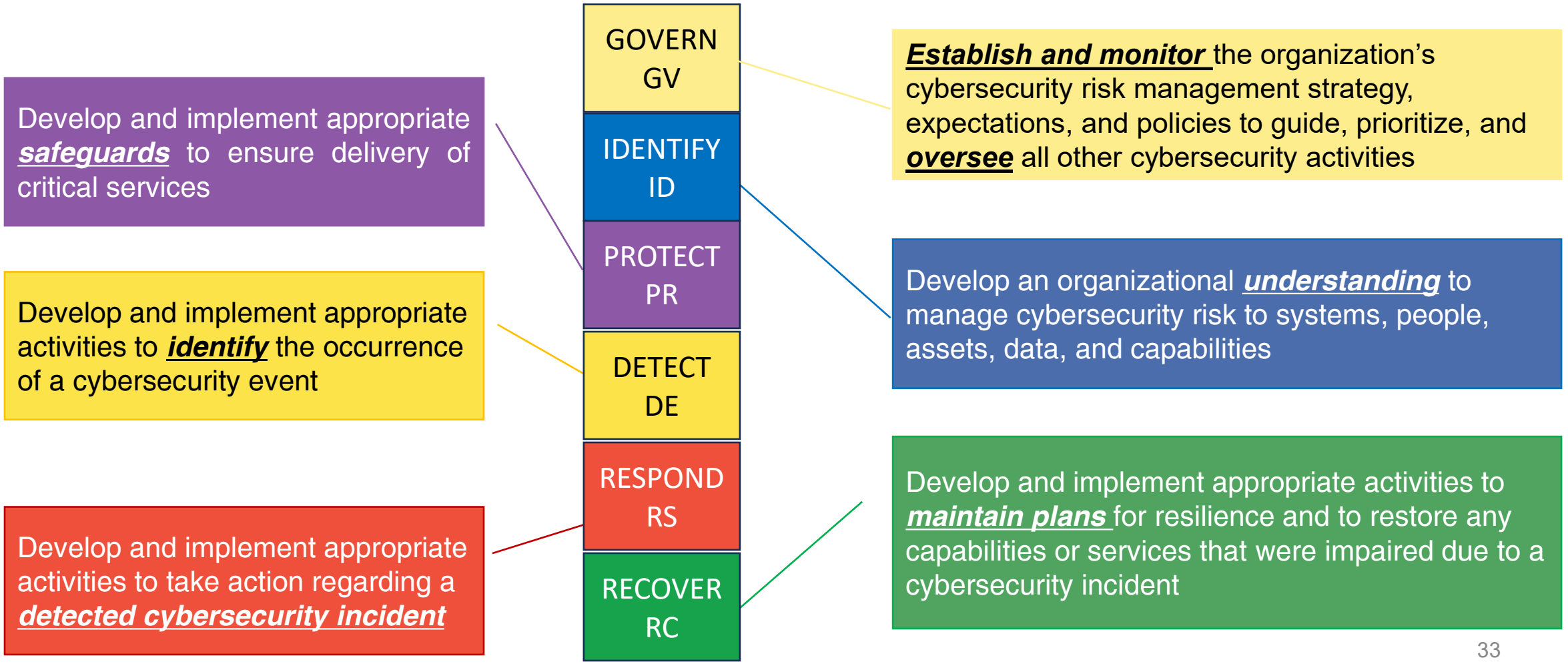
The Core comprises four elements:

1. Functions
2. Categories
3. Subcategories
4. Informative References



# NIST CSF Core: Functions

- Functions organize basic cybersecurity activities at their highest level.



# NIST CSF Core: Other Elements

- **Categories** are the subdivisions of a Function into groups of cybersecurity outcomes closely tied to programmatic needs and particular activities.
  - Examples: “Asset Management,” “Identity Management and Access Control,” and “Detection Processes”

- **Subcategories** further divide a Category into specific outcomes of technical and/or management activities.
  - They provide a set of results that help support achievement of the outcomes in each Category.
  - Examples: “External information systems are catalogued”, “Data-at-rest is protected”, and “Notifications from detection systems are investigated.”

- **Informative References** are specific sections of standards, guidelines, and practices common among critical infrastructure sectors that illustrate a method to achieve the outcomes associated with each Subcategory.

# NIST CSF Core: Govern

| Function | Category | Category Identifier |
|---|---|---|
| Govern (GV) | Organizational Context | GV.OC |
| | Risk Management Strategy | GV.RM |
| | Roles, Responsibilities, and Authorities | GV.RR |
| | Policy | GV.PO |
| | Oversight | GV.OV |
| | Cybersecurity Supply Chain Risk Management | GV.SC |

*Govern establishes the strategic conditions that make the other five functions effective*

- **GV.OC — Organizational Context:** understand the organization's mission, stakeholders, dependencies, and legal, regulatory, and contractual requirements.
- **GV.RM — Risk Management Strategy:** establish priorities, constraints, risk appetite, risk tolerance, and assumptions for cybersecurity decisions.
- **GV.RR — Roles, Responsibilities, and Authorities:** define accountability, decision-making authority, and responsibilities for cybersecurity.
- **GV.PO — Policy:** establish, communicate, and enforce cybersecurity policies.
- **GV.OV — Oversight:** use risk-management results and performance information to review and adjust the cybersecurity strategy.
- **GV.SC — Cybersecurity Supply Chain Risk Management:** identify, assess, manage, monitor, and improve cybersecurity risks arising from suppliers and third parties.

# NIST CSF Core: Identify

| | | |
|---|---|---|
| **Identify (ID)** | Asset Management | ID.AM |
| | Risk Assessment | ID.RA |
| | Improvement | ID.IM |

*You cannot protect what you have not identified*

- **ID.AM — Asset Management:** inventory and manage data, devices, systems, and services.
- **ID.RA — Risk Assessment:** identify and evaluate cybersecurity risks.
- **ID.IM — Improvement:** use lessons learned to improve risk management.

# NIST CSF Core: Protect

| | | |
|---|---|---|
| **Protect (PR)** | Identity Management, Authentication, and Access Control | PR.AA |
| | Awareness and Training | PR.AT |
| | Data Security | PR.DS |
| | Platform Security | PR.PS |
| | Technology Infrastructure Resilience | PR.IR |

*This function reduces the likelihood and impact of an attack*

- **PR.AA — Access Control:** manage identities, authentication, and permissions.
- **PR.AT — Awareness and Training:** train users and partners to perform cybersecurity duties.
- **PR.DS — Data Security:** protect confidentiality, integrity, and availability of data.
- **PR.PS — Platform Security:** harden and secure platforms and devices.
- **PR.IR — Technology Infrastructure Resilience:** ensure infrastructure can withstand and recover from disruption.

# NIST CSF Core: Detect

| | | |
|---|---|---|
| **Detect (DE)** | Continuous Monitoring | DE.CM |
| | Adverse Event Analysis | DE.AE |

*Faster detection means faster response and less damage*

- **DE.AE — Anomalies and Events / Adverse Event Analysis:** identify and analyze abnormal activity.
- **DE.CM — Security Continuous Monitoring:** continuously monitor systems and networks.

# NIST CSF Core: Respond

| | | |
|---|---|---|
| **Respond (RS)** | Incident Management | RS.MA |
| | Incident Analysis | RS.AN |
| | Incident Response Reporting and Communication | RS.CO |
| | Incident Mitigation | RS.MI |

*A good response reduces the operational and reputational impact of an incident*

- **RS.MA — Incident Management:** maintain and execute incident response procedures.
- **RS.AN — Analysis:** analyze the incident to support response and recovery.
- **RS.CO — Communications:** coordinate internal and external communications.
- **RS.MI — Mitigation:** contain, eradicate, and reduce incident impact.

# NIST CSF Core: Recover

| | | |
|---|---|---|
| **Recover (RC)** | Incident Recovery Plan Execution | RC.RP |
| | Incident Recovery Communication | RC.CO |

*Recovery is not only restoration, but also improvement*

- **RC.RP — Recovery Planning:** execute recovery processes and restore services.
- **RC.CO — Recovery Communications:** communicate recovery status and return-to-normal progress.

# NIST CSF Core as a whole

| Function | Category | Category Identifier |
|---|---|---|
| **Govern (GV)** | Organizational Context | GV.OC |
| | Risk Management Strategy | GV.RM |
| | Roles, Responsibilities, and Authorities | GV.RR |
| | Policy | GV.PO |
| | Oversight | GV.OV |
| | Cybersecurity Supply Chain Risk Management | GV.SC |
| **Identify (ID)** | Asset Management | ID.AM |
| | Risk Assessment | ID.RA |
| | Improvement | ID.IM |
| **Protect (PR)** | Identity Management, Authentication, and Access Control | PR.AA |
| | Awareness and Training | PR.AT |
| | Data Security | PR.DS |
| | Platform Security | PR.PS |
| | Technology Infrastructure Resilience | PR.IR |
| **Detect (DE)** | Continuous Monitoring | DE.CM |
| | Adverse Event Analysis | DE.AE |
| **Respond (RS)** | Incident Management | RS.MA |
| | Incident Analysis | RS.AN |
| | Incident Response Reporting and Communication | RS.CO |
| | Incident Mitigation | RS.MI |
| **Recover (RC)** | Incident Recovery Plan Execution | RC.RP |
| | Incident Recovery Communication | RC.CO |



# NIST CSF: Implementation Tiers

- The Framework Implementation Tiers provide context on **how** an organization views cybersecurity risk and the processes in place to manage that risk
- Ranging from Partial (Tier 1) to Adaptive (Tier 4)
- Tiers describe an increasing degree of rigor and sophistication in cybersecurity risk management practices.

- **NOTE** While organizations identified as Tier 1 (Partial) are encouraged to consider moving toward Tier 2 or greater, Tiers do not represent maturity levels.
  - Tiers are meant to support organizational decision making about how to manage cybersecurity risk, as well as which dimensions of the organization are higher priority and could receive additional resources.
  - Progression to higher Tiers is encouraged when a cost-benefit analysis indicates a feasible and cost-effective reduction of cybersecurity risk.

# NIST CSF: Implementation Tiers

| | Risk Management Process | Integrated Risk Management Program | External Participation |
|---|---|---|---|
| **TIER 1 Partial** | - Lack of formalization<br>- Ad hoc and sometimes reactive management<br>- Prioritization of activities may not be directly based on by organizational risk objectives, the threat environment, or business/mission requirements | - Limited awareness of cybersecurity risk at the organizational level<br>- Irregular, case-by-case basis due to varied experience or information gained from outside sources<br>- The organization may not have in place information sharing processes | No collaboration |

# NIST CSF: Implementation Tiers

| | Risk Management Process | Integrated Risk Management Program | External Participation |
|---|---|---|---|
| **TIER 2 Risk Informed** | - Management approval but possible absence of clear policies<br>- Prioritization of activities may not be directly based on by organizational risk objectives | - Awareness of cybersecurity risk at the organizational level but not an organization-wide approach to managing cybersecurity<br>- Information sharing within the organization on an informal basis.<br>- Not all levels of the organization are involved<br>- Cyber risk assessment of organizational and external assets occurs, but is not typically repeatable or reoccurring. | Low Collaboration |

# NIST CSF: Implementation Tiers

| | Risk Management Process | Integrated Risk Management Program | External Participation |
|---|---|---|---|
| **TIER 3 Repeatable** | - Formal approval and definition of policy.<br>- Regularly updated | - There is an organization-wide approach to manage cybersecurity risk. | High Collaboration |
| **TIER 4 Adaptive** | - Standards and best Practices are applied<br>- Continuous improvement process | - There is an organization-wide approach to managing cybersecurity risk that uses risk-informed policies, processes, and procedures to address potential cybersecurity events | Full Collaboration |

# NIST CSF: Profiles

- The Framework Profile is the alignment of the Functions, Categories, and Subcategories with the business requirements, risk tolerance, and resources of the organization.

- They can be used to describe the current state or the desired target state of specific cybersecurity activities
  - The **Current Profile** indicates the cybersecurity outcomes that are currently being achieved.
  - The **Target Profile** indicates the outcomes needed to achieve the desired cybersecurity risk management goals.
    - Support gap analysis

- This Framework does not prescribe Profile templates, allowing for flexibility in implementation

# How to use NIST CSF

1. Basic Review of Cybersecurity Practices
2. Establishing or Improving a Cybersecurity Program
3. Communicating Cybersecurity Requirements with Stakeholders
4. Buying Decisions
5. Identifying Opportunities for New or Revised Informative References
6. Methodology to Protect Privacy and Civil Liberties
7. Self-Assessing Cybersecurity Risk with the Framework

# NIST CSF in action: context

https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf

- **Entity: University Research Department**
- **Scenario:** A university research department wants to protect sensitive research data, cloud services, staff accounts, and laboratory systems.
- **Organizational scope**
  - Research servers and laboratory systems.
  - Cloud storage and collaboration platforms.
  - Research data and personal information.
  - Staff, researchers, students, suppliers, and external partners.
  - Legal, contractual, and university security requirements.

# NIST CSF in action: profiles

| Function and category | Current state | Target state | Priority |
|---|---|---|---|
| GV.OC — Organizational Context | Critical research services and external dependencies are not fully documented. | Document critical services, stakeholders, dependencies, and applicable requirements. | High |
| GV.RR — Roles, Responsibilities, and Authorities | Security responsibilities are informally assigned to IT staff. | Approve clear responsibilities for management, IT, researchers, suppliers, and incident response. | High |
| GV.SC — Cybersecurity Supply Chain Risk Management | Cloud and software suppliers are reviewed inconsistently. | Establish security requirements, due diligence, monitoring, and incident obligations for suppliers. | High |
| ID.AM — Asset Management | Hardware is inventoried, but cloud services and research datasets are incomplete. | Maintain an updated inventory with owners, classifications, dependencies, and criticality. | High |
| ID.RA — Risk Assessment | Risk assessments are performed after major incidents or projects. | Perform periodic and event-driven risk assessments using a documented methodology. | High |
| PR.AA — Identity Management and Access Control | MFA protects administrators but not all users. | Require MFA for all accounts and review privileged access regularly. | High |
| PR.DS — Data Security | Backups exist, but encryption and restoration tests vary between systems. | Encrypt sensitive data, define retention rules, and test backup restoration regularly. | High |
| DE.CM — Continuous Monitoring | Logs are collected from selected systems and reviewed manually. | Centralize important logs and generate alerts for suspicious activity. | Medium |
| RS.MA — Incident Management | General IT procedures exist, but no research-specific playbook is available. | Establish, test, and maintain incident-response procedures and escalation paths. | High |
| RC.RP — Recovery Plan Execution | Services can be restored, but recovery priorities and objectives are unclear. | Define recovery priorities, responsibilities, RTOs, RPOs, and recovery exercises. | Medium |

# NIST CSF in action: tiers

**Current tier: Tier 2 — Risk Informed**

- The department is best characterized as **Tier 2 — Risk Informed** because it recognizes cybersecurity risks and performs some risk-management activities, but practices are not yet consistently established or applied across the organization.

Typical evidence includes:

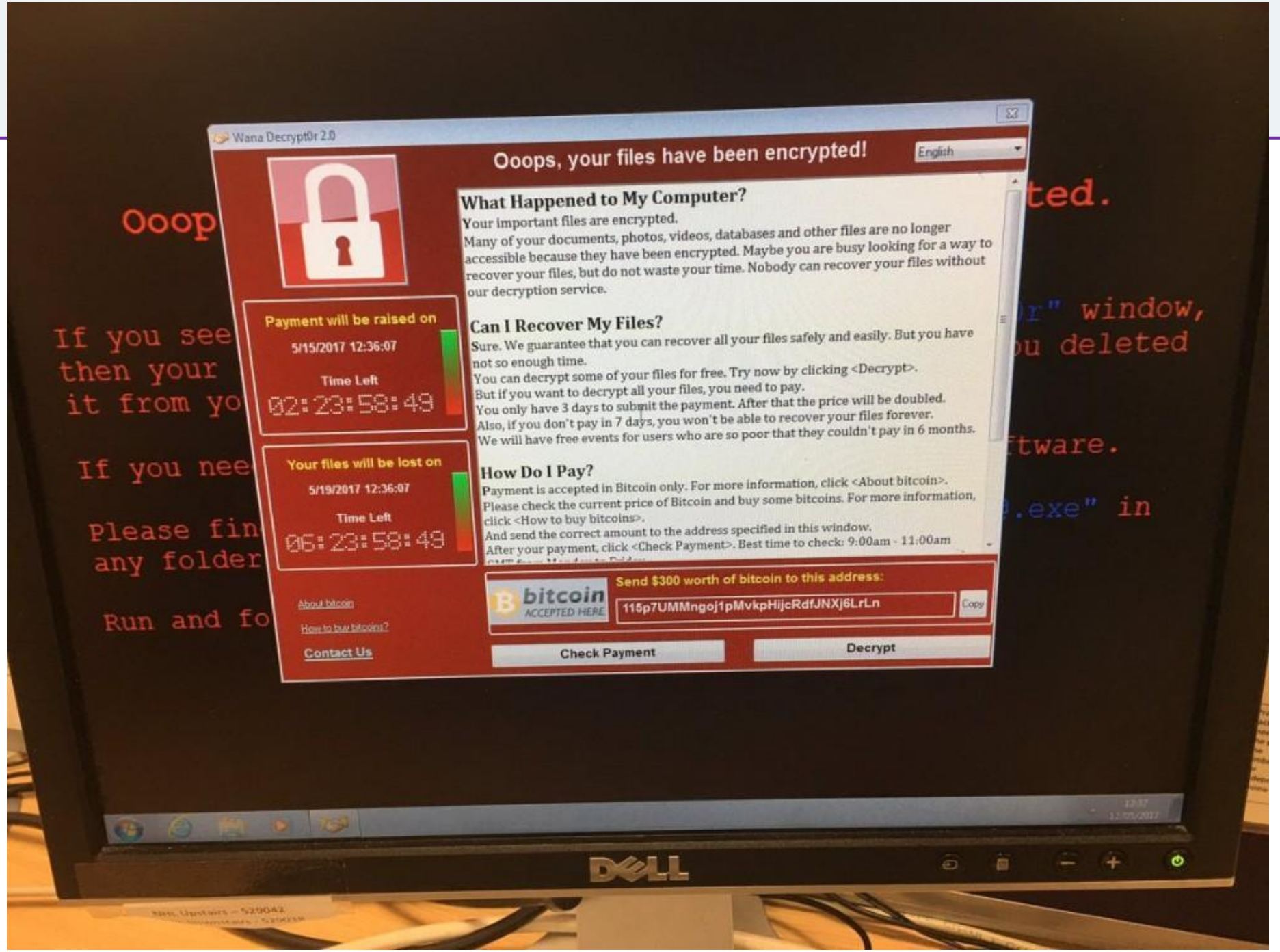
- Security risks are discussed in IT and project meetings.
- Some systems use MFA, backups, logging, and access reviews.
- Risk assessments occur for selected projects or incidents.
- Supplier risks are known but not managed through a consistent process.
- Cybersecurity information is shared mainly through informal communication.
- Procedures vary between laboratories and research teams.

**Target tier: Tier 3 — Repeatable**

- The target is **Tier 3 — Repeatable**, where cybersecurity risk-management practices are formally approved, documented, consistently implemented, and regularly reviewed across the department.

To reach Tier 3, the department should:

- Approve an organization-wide cybersecurity risk-management policy.
- Assign formal roles and responsibilities.
- Maintain complete asset and data inventories.
- Apply the same risk-assessment method to all relevant systems.
- Require MFA and periodic access reviews.
- Establish standardized supplier-security requirements.
- Centralize monitoring and incident reporting.
- Test incident-response and disaster-recovery plans.
- Use metrics and management reviews to track improvement.


Wana Decrypt0r 2.0
Ooops, your files have been encrypted!
English
What Happened to My Computer?
Your important files are encrypted.
Many of your documents, photos, videos, databases and other files are no longer accessible because they have been encrypted. Maybe you are busy looking for a way to recover your files, but do not waste your time. Nobody can recover your files without our decryption service.
Can I Recover My Files?
Sure. We guarantee that you can recover all your files safely and easily. But you have not so enough time.
You can decrypt some of your files for free. Try now by clicking <Decrypt>.
But if you want to decrypt all your files, you need to pay.
You only have 3 days to submit the payment. After that the price will be doubled.
Also, if you don't pay in 7 days, you won't be able to recover your files forever.
We will have free events for users who are so poor that they couldn't pay in 6 months.
How Do I Pay?
Payment is accepted in Bitcoin only. For more information, click <About bitcoin>.
Please check the current price of Bitcoin and buy some bitcoins. For more information, click <How to buy bitcoins>.
And send the correct amount to the address specified in this window.
After your payment, click <Check Payment>. Best time to check: 9:00am - 11:00am
Payment will be raised on
5/15/2017 12:36:07
Time Left
02:23:58:49
Your files will be lost on
5/19/2017 12:36:07
Time Left
06:23:58:49
About bitcoin
How to buy bitcoins?
Contact Us
bitcoin
ACCEPTED HERE
Send $300 worth of bitcoin to this address:
115p7UMMngoj1pMvkpHijcRdfJNXj6LrLn
Copy
Check Payment
Decrypt
Ooop
If you see
then your
it from yo
If you nee
Please fin
any folder
Run and fo
ted.
r" window,
u deleted
ftware.
.exe" in
DELL

# What Tier during WannaCry?

**WannaCry has just hit your organization.**

- You discover that:
- IT knew that some machines were unpatched.
- There was no complete inventory of Windows systems.
- Patching was performed manually when administrators had time.
- The security team had previously warned management about the risk.
- There was no organization-wide process for prioritizing vulnerabilities.
- After the attack, management asks: “How did we not know this was going to happen?”

**Which NIST CSF Implementation Tier best describes this organization?**

- Tier 1
- Tier 2
- Tier 3
- Tier 4

**What would you change to improve Tier ?**

# Framework

Italian NCF

# National Cybersecurity Framework (ITA)

- Bring cyber risk awareness to the highest levels of the business ...
  - No longer just a matter for technical staff
  - Make organizations include cyber risk in risk management as part of an economic risk
- ... considering the Italian economic landscape
  - 69% of the GDP is due to **SME**
  - Very few large national enterprises: ~ 0.1%

- Create something which is recognized at international level
  - Improve information sharing capacity
  - Increase the duty of care at the national level

- Do not reinvent the wheel
  - It makes no sense to create a new framework from scratch
  - Use a recognized framework as a starting point:
    - NIST CSF

# What the National Framework is and what is not

- The National Framework is not a Standard
  - It is not certifiable!
- It is a tool for self-assessment
- Allows organizations to assess their current cybersecurity posture («*current profile*») and define the desired one («*target profile*»)
- Support in the gap analysis and the definition of a roadmap to close the gap between the current and the target profile

# Contextualization

The National Framework can be «customized» so as to adapt it to a specific context (e.g. sectors, public administrations, organizations)

The Framework can be adapted to a specific scenario through a **Contextualization**:

- Selection of Subcategories
- Definition of the Priority Level for each selected Subcategory
- Definition of the Maturity Levels and…
- ... of the Controls to reach them

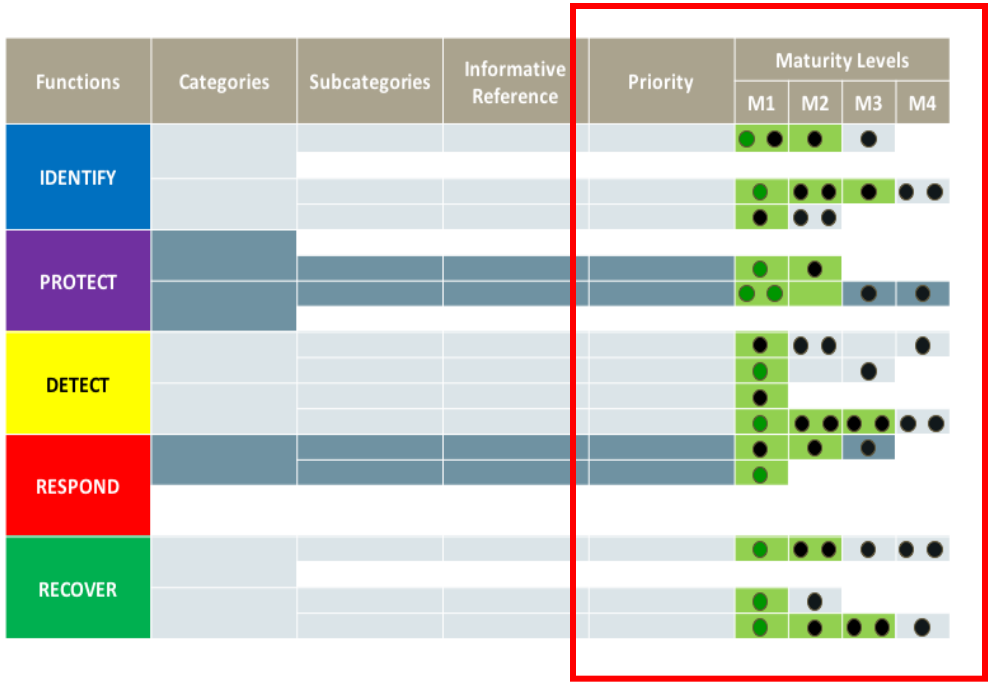
Given a Contextualization, it is possible to define:

- The Current Profile

  *The "as is" state*

- A Target Profile

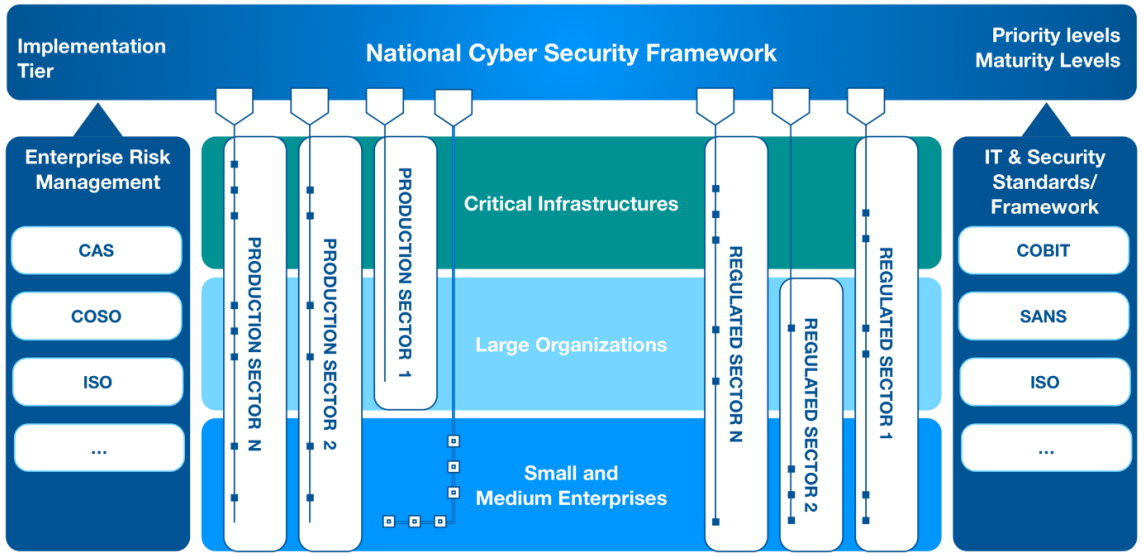
  *The "to be" state*



# Contextualization

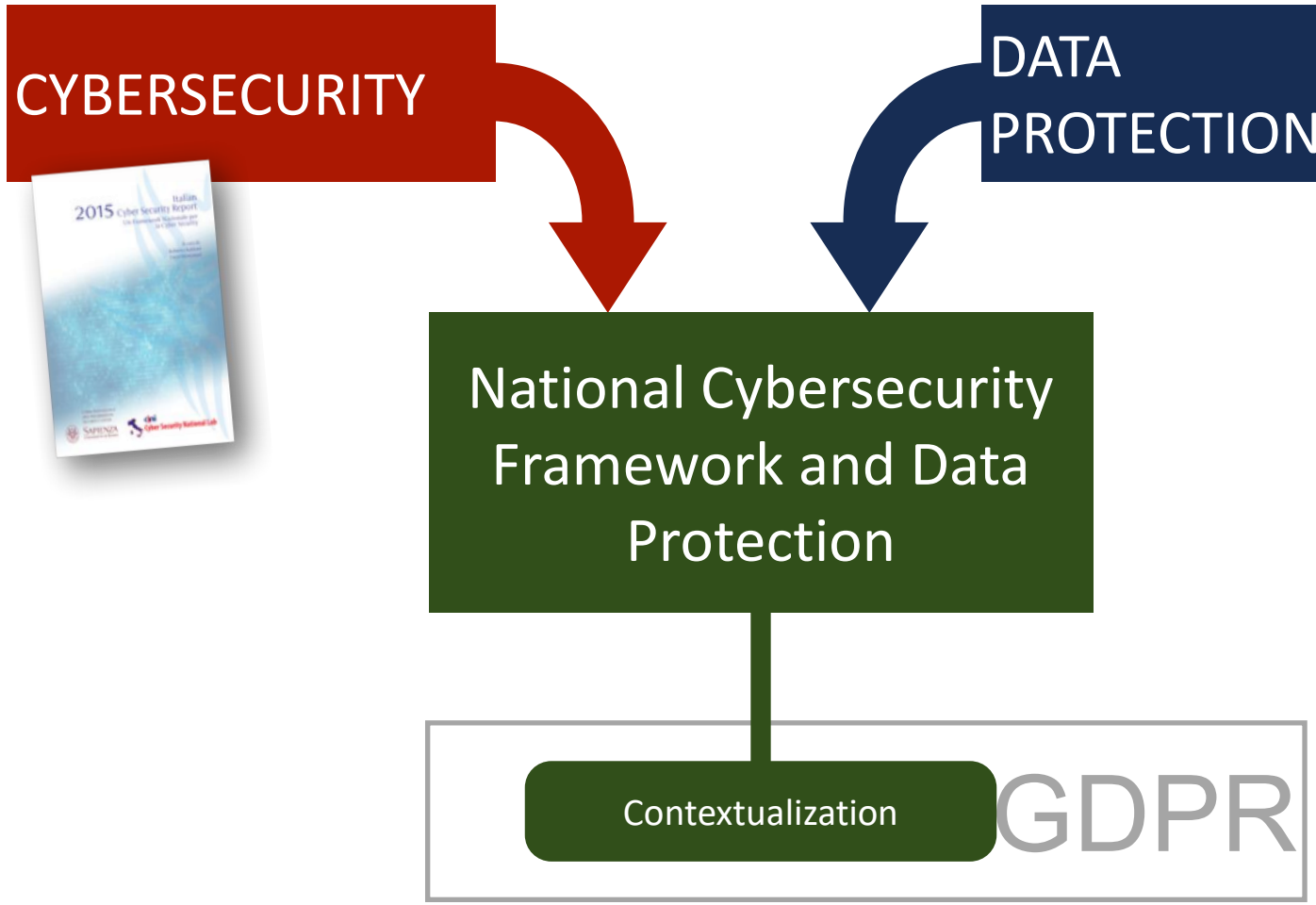
A contextualization can be defined for

- A single organization
- An entire economic/productive sector
- Groups of organizations based on scale (e.g. SME, Large Enterprises)
- Organizations belonging to regulated sectors (e.g. PAs, banks, …)
- Critical Infrastructures

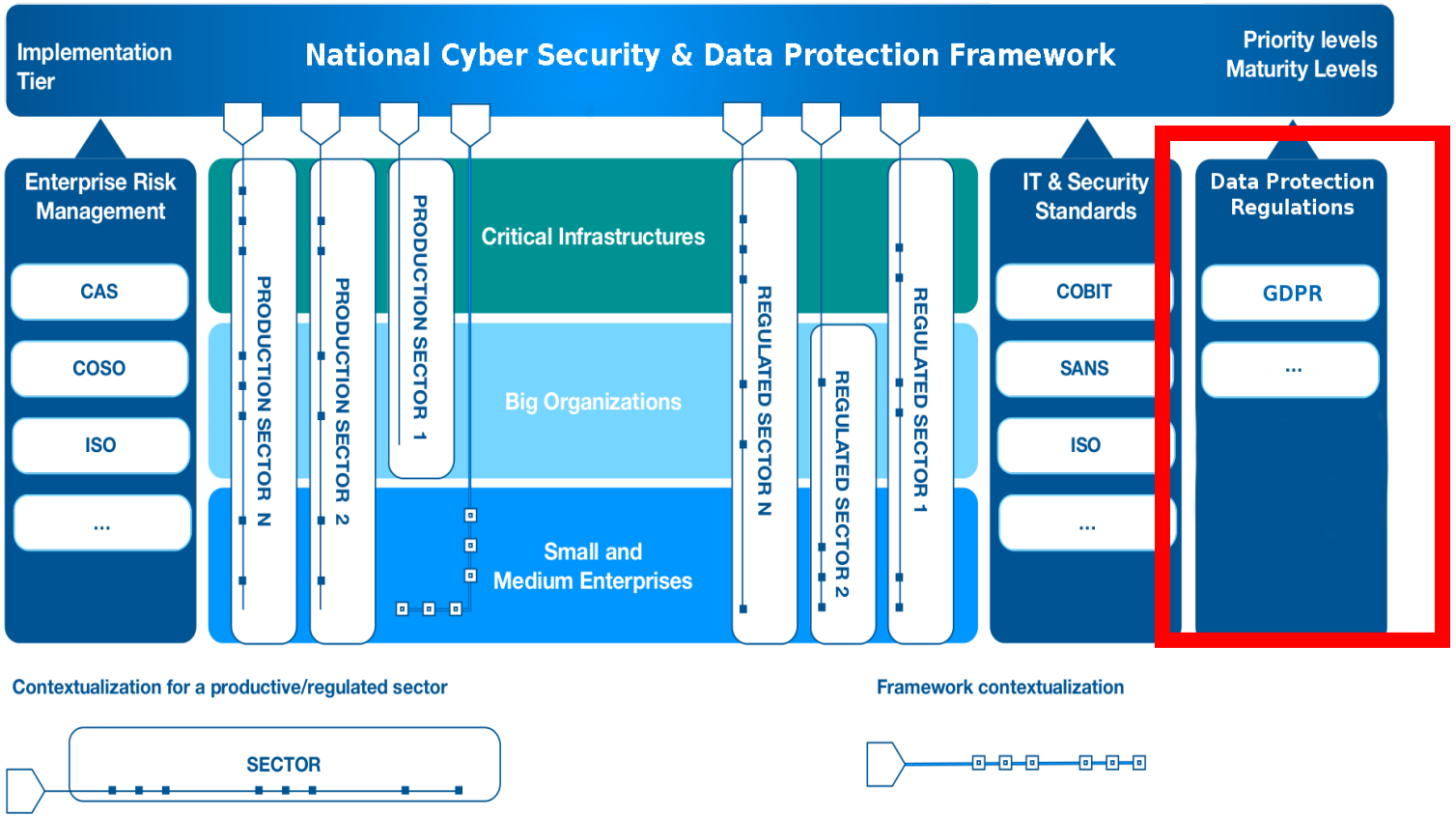


# Contextualization for GDPR

https://www.cybersecurityframework.it/sites/default/files/Metodologia_Assessment_Framework_Nazionale_-_v1.0.pdf



# Framework 2.0



# Framework 2.0

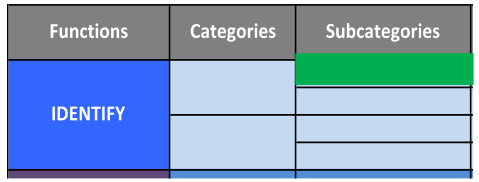
4 possible cases

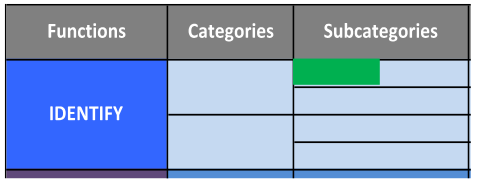
1. Perfect placement
   - On 1 single subcategory
   - On more than one subcategory

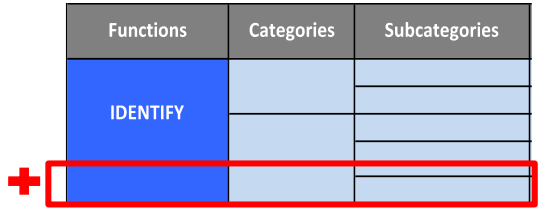
2. Partial placement
   - On 1 single subcategory
   - On more than one subcategory

3. Not possible placement
   - Needs for a new subcategory

4. Not needed placement






# Implementation

ISO 27002

# ISO 27002

- ISO/IEC 27002 is the companion standard on information security controls.
- It provides a reference set of generic controls together with implementation guidance.
- It is designed to be used within an ISMS based on ISO/IEC 27001, for implementing commonly accepted controls, or for developing organization-specific guidance.

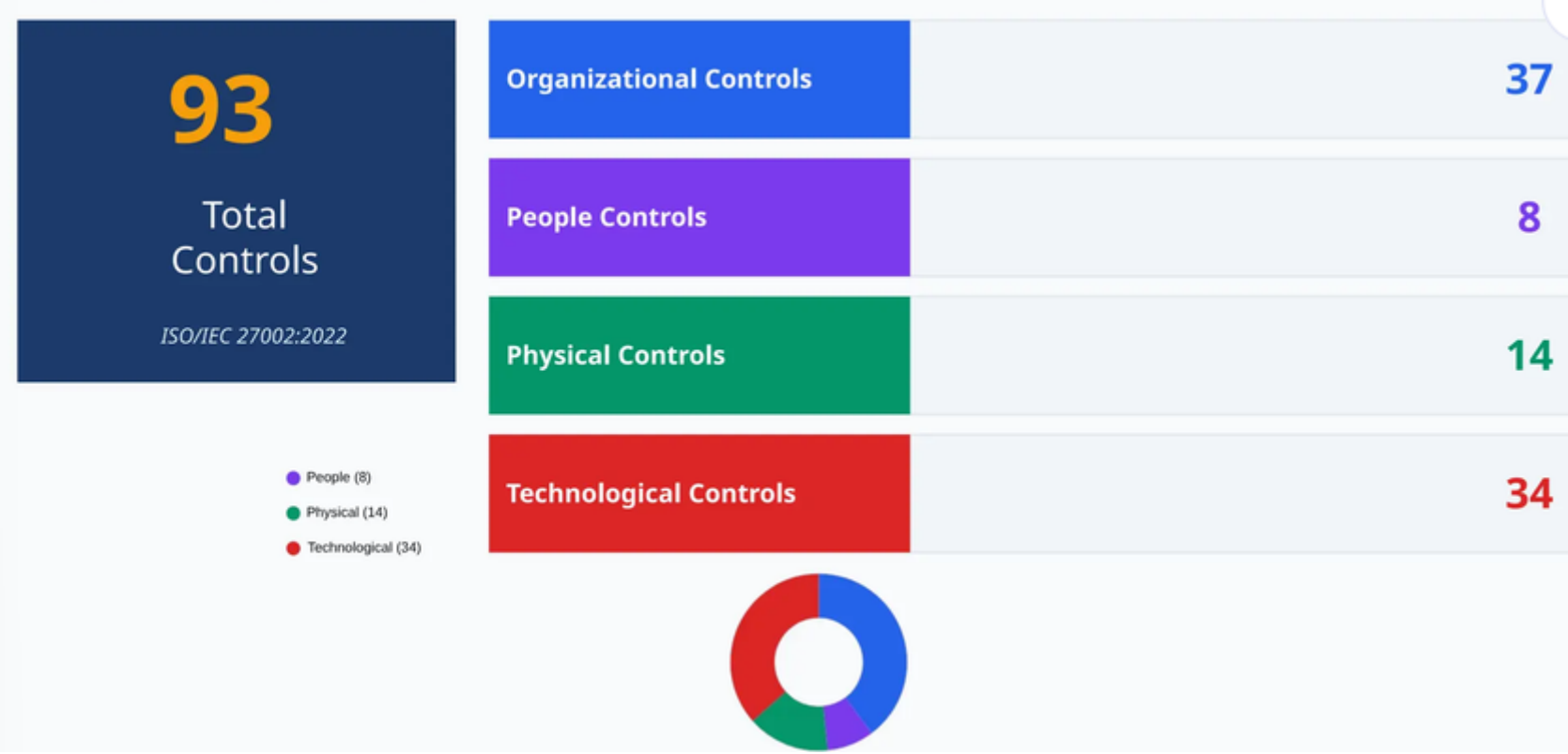
- If ISO/IEC 27001 tells an organization **what must be managed**, ISO/IEC 27002 helps explain how controls can be understood and implemented.
- ISO/IEC 27002 is therefore not a certification standard by itself; certification is against ISO/IEC 27001, not 27002.
- In practical terms, 27002 gives security teams more detailed guidance for selecting and applying controls consistently.

# Structure of ISO/IEC 27002:2022

- The 2022 edition of ISO/IEC 27002 organizes its controls into **four themes**:
  - Organizational: cover governance, policies, supplier relationships, incident management, and related management practices.
  - People: address topics such as screening, awareness, training, and responsibilities of personnel
  - Physical: concern the protection of facilities, equipment, and physical environments
  - Technological: cover areas such as access control, logging, malware protection, secure development, and network security

- The control set includes **93 controls**.
- This reorganization was intended to simplify the structure and make the control catalogue easier to navigate and apply

# Structure of ISO/IEC 27002:2022



# ISO 27002: Organizational Controls

| | |
|---|---|
| 5.1 | Policies for information security |
| 5.2 | Information security roles & responsibilities |
| 5.3 | Segregation of duties |
| 5.4 | Management responsibilities |
| 5.5 | Contact with authorities |
| 5.6 | Contact with special interest groups |
| 5.7 | Threat intelligence (NEW) |
| 5.8 | Information security in project management |
| 5.9 | Inventory of information & assets |
| 5.10 | Acceptable use of information & assets |
| 5.11 | Return of assets |
| 5.12–5.14 | Information classification & labelling |
| 5.15–5.18 | Access control & identity management |
| 5.19–5.22 | Supplier security policies |
| 5.23 | Information security in cloud services (NEW) |
| 5.24–5.30 | Incident management & ICT continuity |
| 5.31–5.37 | Legal, compliance, documentation & audits |

# ISO 27002: People Controls

| | | | |
|---|---|---|---|
| 6.1 | **Screening**<br>Background verification checks on all candidates prior to employment | 6.5 | **Responsibilities after Termination**<br>Security obligations that remain after employment ends |
| 6.2 | **Terms & Conditions of Employment**<br>Employees agree to information security responsibilities | 6.6 | **Confidentiality or NDA Agreements**<br>Legal agreements reflecting organizational security needs |
| 6.3 | **Information Security Awareness, Education & Training**<br>Ongoing security awareness programs for all personnel | 6.7 | **Remote Working**<br>Security controls for personnel working remotely |
| 6.4 | **Disciplinary Process**<br>Formal process for handling security policy violations | 6.8 | **Information Security Event Reporting**<br>Mechanism to report suspected security events promptly |

# ISO 27002: Physical Controls

| | | | |
|---|---|---|---|
| 7.1 | Physical security perimeters | 7.8 | Equipment siting & protection |
| 7.2 | Physical entry controls | 7.9 | Security of assets off-premises |
| 7.3 | Securing offices, rooms & facilities | 7.10 | Storage media |
| 7.4 | Physical security monitoring (NEW) NEW | 7.11 | Supporting utilities |
| 7.5 | Protecting against physical & environmental threats | 7.12 | Cabling security |
| 7.6 | Working in secure areas | 7.13 | Equipment maintenance |
| 7.7 | Clear desk & clear screen | 7.14 | Secure disposal or re-use of equipment |

# ISO 27002: Technological Controls

**Access & Identity (8.1–8.6)**

- User endpoint devices
- Privileged access rights
- Access control
- Authentication
- Identity management
- Privileged utilities

**Security Operations (8.15–8.22)**

- Logging & monitoring
- Clock synchronization
- Web filtering (NEW)
- Network security
- Configuration mgmt (NEW)
- Vulnerability management

**Data Protection (8.10–8.12, 8.24)**

- Information deletion (NEW)
- Data masking (NEW)
- Data leakage prevention (NEW)
- Cryptography

**Secure Dev & Acquisition (8.25–8.34)**

- Secure development lifecycle
- Secure coding (NEW)
- Security testing
- Outsourced development
- Separation of environments

# ISO 27001 Annex A vs ISO 27002

Annex A of ISO/IEC 27001 contains a catalogue of control objectives and controls that organizations can select as part of their Information Security Management System (ISMS). It is **normative** and linked to the risk treatment process.

Example:

| | | |
|---|---|---|
| A.9.4.5 | Access control to program source code | *Control*<br>Access to program source code shall be restricted. |

ISO/IEC 27002:2022 provides **detailed implementation** guidance, purpose statements and attributes for the same 93 controls referenced in ISO/IEC 27001, helping translate Annex A into actionable operative measures.

Example:

**9.4.5 Access control to program source code**

Control

Access to program source code should be restricted.

Implementation guidance

Access to program source code and associated items (such as designs, specifications, verification plans and validation plans) should be strictly controlled, in order to prevent the introduction of unauthorized functionality and to avoid unintentional changes as well as to maintain the confidentiality of valuable intellectual property. For program source code, this can be achieved by controlled central storage of such code, preferably in program source libraries. The following guidelines should then be considered to control access to such program source libraries in order to reduce the potential for corruption of computer programs:

a) where possible, program source libraries should not be held in operational systems;

b) the program source code and the program source libraries should be managed according to established procedures;

c) support personnel should not have unrestricted access to program source libraries;

d) the updating of program source libraries and associated items and the issuing of program sources to programmers should only be performed after appropriate authorization has been received;

e) program listings should be held in a secure environment;

f) an audit log should be maintained of all accesses to program source libraries;

g) maintenance and copying of program source libraries should be subject to strict change control procedures (see 14.2.2).

If the program source code is intended to be published, additional controls to help getting assurance on its integrity (e.g. digital signature) should be considered.

# Implementation

NIST SP 800-53

# NIST SP 800-53: Security and Privacy Controls

- NIST exceptionally publishes technical reports that provides guidelines, recommendations, and reference material, especially for information security and related topics → **Special Publications (SPs)**
- The SP 800 series is NIST's primary channel for publishing computer/cyber/information security guidelines, recommendations, and technical specifications.
- NIST Special Publication 800-53 provides a comprehensive catalog of security and privacy controls for information systems and organizations.
  - The controls are **flexible and customizable**: organizations select and tailor them according to their mission, business needs, risk tolerance, and operating environment.
  - NIST SP 800-53 is a **control catalog** and implementation reference, rather than a certification standard such as ISO/IEC 27001.

Aims:

1. Provide a security and privacy controls catalogue for federal organizations and information systems
2. Provide a process to select controls to protect *Mission, functions, image, reputation, assets, individuals, state* from cyber attacks, disasters, malfunctions and human errors
3. Provide a methodology for selecting critical controls (**baseline**)

# Key Concepts

- **Security controls:** Safeguards and countermeasures that protect the confidentiality, integrity, and availability of systems and information.
- **Privacy controls:** Administrative, technical, and physical safeguards that manage privacy risks and support compliance with applicable privacy requirements.
- **Control families:** Groups of controls organized by topic, such as access control, incident response, risk assessment, and supply-chain risk management.
- **Control enhancements:** Additional requirements that strengthen or extend a base control for higher-risk environments.
- **Tailoring:** The process of adapting controls to a specific organization, system, mission, technology, or risk profile.

# NIST SP 800-53 Rev. 5

- Revision 5 integrates security and privacy controls into a single consolidated catalog.
- It organizes the catalog into **20 control families**.
- Each control generally includes:
  - a base control,
  - discussion,
  - related controls,
  - control enhancements,
  - references.
- The controls are intended to be outcome-oriented and adaptable rather than implemented as an identical checklist in every organization.

**Table of Contents**


**CHAPTER ONE** INTRODUCTION ..... 1
1.1 PURPOSE AND APPLICABILITY ..... 2
1.2 TARGET AUDIENCE ..... 3
1.3 RELATIONSHIP TO OTHER SECURITY CONTROL PUBLICATIONS ..... 3
1.4 ORGANIZATIONAL RESPONSIBILITIES ..... 4
1.5 ORGANIZATION OF THIS SPECIAL PUBLICATION ..... 6
**CHAPTER TWO** THE FUNDAMENTALS ..... 7
2.1 MULTITIERED RISK MANAGEMENT ..... 7
2.2 SECURITY CONTROL STRUCTURE ..... 9
2.3 SECURITY CONTROL BASELINES ..... 12
2.4 SECURITY CONTROL DESIGNATIONS ..... 14
2.5 EXTERNAL SERVICE PROVIDERS ..... 17
2.6 ASSURANCE AND TRUSTWORTHINESS ..... 20
2.7 REVISIONS AND EXTENSIONS ..... 26
**CHAPTER THREE** THE PROCESS ..... 28
3.1 SELECTING SECURITY CONTROL BASELINES ..... 28
3.2 TAILORING BASELINE SECURITY CONTROLS ..... 30
3.3 CREATING OVERLAYS ..... 40
3.4 DOCUMENTING THE CONTROL SELECTION PROCESS ..... 42
3.5 NEW DEVELOPMENT AND LEGACY SYSTEMS ..... 44
**APPENDIX A** REFERENCES ..... A-1
**APPENDIX B** GLOSSARY ..... B-1
**APPENDIX C** ACRONYMS ..... C-1
**APPENDIX D** SECURITY CONTROL BASELINES – SUMMARY ..... D-1
**APPENDIX E** ASSURANCE AND TRUSTWORTHINESS ..... E-1
**APPENDIX F** SECURITY CONTROL CATALOG ..... F-1
**APPENDIX G** INFORMATION SECURITY PROGRAMS ..... G-1
**APPENDIX H** INTERNATIONAL INFORMATION SECURITY STANDARDS ..... H-1
**APPENDIX I** OVERLAY TEMPLATE ..... I-1
**APPENDIX J** PRIVACY CONTROL CATALOG ..... J-1

# SP800-53: Security control families

For ease of use in the security control selection and specification process, controls are organized into **20 families**.

Each family contains security controls related to the general security topic of the family.

**TABLE 1: SECURITY AND PRIVACY CONTROL FAMILIES**

| ID | FAMILY | ID | FAMILY |
|---|---|---|---|
| AC | Access Control | PE | Physical and Environmental Protection |
| AT | Awareness and Training | PL | Planning |
| AU | Audit and Accountability | PM | Program Management |
| CA | Assessment, Authorization, and Monitoring | PS | Personnel Security |
| CM | Configuration Management | PT | PII Processing and Transparency |
| CP | Contingency Planning | RA | Risk Assessment |
| IA | Identification and Authentication | SA | System and Services Acquisition |
| IR | Incident Response | SC | System and Communications Protection |
| MA | Maintenance | SI | System and Information Integrity |
| MP | Media Protection | SR | Supply Chain Risk Management |

# SP800-53: Security control structure

| Section | Description |
|---|---|
| Control | Prescribes specific security-related activities or actions to be carried out by organizations or by information systems |
| Supplemental guidance | Provides non-prescriptive, additional information for a specific security control. |
| Control enhancements | Provides statements of security capability to:<br>(i) add functionality/specificity to a control; and/or<br>(ii) increase the strength of a control. |
| References | includes a list of applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidelines that are relevant to a particular security control |

# SP 800-53: Security control example

https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf

**AU-3 CONTENT OF AUDIT RECORDS**

Control: The information system generates audit records containing information that establishes what type of event occurred, when the event occurred, where the event occurred, the source of the event, the outcome of the event, and the identity of any individuals or subjects associated with the event.

Supplemental Guidance: Audit record content that may be necessary to satisfy the requirement of this control includes, for example, time stamps, source and destination addresses, user/process identifiers, event descriptions, success/fail indications, filenames involved, and access control or flow control rules invoked. Event outcomes can include indicators of event success or failure and event-specific results (e.g., the security state of the information system after the event occurred). Related controls: AU-2, AU-8, AU-12, SI-11.

Control Enhancements:

**(1)** *CONTENT OF AUDIT RECORDS | ADDITIONAL AUDIT INFORMATION*

**The information system generates audit records containing the following additional information: [*Assignment: organization-defined additional, more detailed information*].**

Supplemental Guidance: Detailed information that organizations may consider in audit records includes, for example, full-text recording of privileged commands or the individual identities of group account users. Organizations consider limiting the additional audit information to only that information explicitly needed for specific audit requirements. This facilitates the use of audit trails and audit logs by not including information that could potentially be misleading or could make it more difficult to locate information of interest.

**(2)** *CONTENT OF AUDIT RECORDS | CENTRALIZED MANAGEMENT OF PLANNED AUDIT RECORD CONTENT*

**The information system provides centralized management and configuration of the content to be captured in audit records generated by [*Assignment: organization-defined information system components*].**

Supplemental Guidance: This control enhancement requires that the content to be captured in audit records be configured from a central location (necessitating automation). Organizations coordinate the selection of required audit content to support the centralized management and configuration capability provided by the information system. Related controls: AU-6, AU-7.

References: None.

# • SP 800-53: Security control baseline (SP 800-53B)

A companion document to SP 800-53 → **SP 800-53B**

- **Aim**: To assist organizations in making the appropriate selection of security controls for information systems
- **Baseline controls**
  - Are the **starting point** for the security control selection process (as described in the document)
  - Are chosen based on the security category and associated impact level of information systems
  - Three security control baselines have been identified corresponding to the *low-impact*, *moderate-impact*, and *high-impact* information systems

**Limitations:**

- Tied to the concept of federal information systems, to the US Legislation, policies, directives, instructions, regulations, and memoranda, all US-based (over 50 in total)
- Very complex and oriented to operational people

# SP 800-53: Security control baseline example

**Scenario**

- You have an internal web application for a federal agency that processes sensitive but unclassified data.
- A breach would cause **serious** (not catastrophic) impact on confidentiality, integrity, or availability, so the system is categorized as **Moderate-impact** under FIPS 199.

**Actions**

From **SP 800-53B** you select the **Moderate security control baseline**, which includes roughly 287 security controls and enhancements from SP 800-53.

https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53B.pdf

# Implementation

CIS Controls

# Center for Internet Security (CIS) Controls

The Center for Internet Security (CIS) is a USA non-profit organization focused on improving global cybersecurity standards and practices.

CIS works with various experts from industry, government, and academia to develop best practices and guidelines that help organizations secure their IT systems and data against cyber threats.

They are well-known for the publication of CIS controls:

- a prioritized **set of actions** designed to help organizations strengthen their cybersecurity posture.
- developed by a **global community** of cybersecurity experts and provide clear, actionable steps to protect against the most prevalent cyber threats.
- organized into different categories and ranked based on effectiveness and ease of implementation, making them highly practical for organizations of all sizes.

# CIS Controls Overview

Design principles:

- **Offense informs defense** → controls are selected and prioritized using empirical knowledge of attacker behavior and how to stop it.
- **Focus and feasibility** → each safeguard is specific, practical to implement, and avoids “nice-to-have” or purely theoretical requirements.
- **Measurable and aligned** → safeguards are written to be measurable and aligned with other frameworks (NIST CSF, ISO 27001, OWASP, MITRE ATT&CK, etc.).

Structure:

- CIS Controls v8.1 consists of 18 top-level controls broken down into **153 safeguards**, each describing a single actionable requirement.
  - Basic Controls (1-6): Fundamental cybersecurity measures
  - Foundational Controls (7-16): Advanced security practices
  - Organizational Controls (17-18): Policies and processes for security.
- Controls are numbered by priority



# CIS Controls: Implementation Groups (IG)

Safeguards are assigned to **Implementation Groups** based on organizational size, risk and resources: IG1, IG2, IG3.

- **IG1 (basic cyber hygiene)** – ~56 safeguards that every organization should implement; focused on the most common attack vectors.
- **IG2 and IG3** progressively add more advanced safeguards for organizations with higher risk, more complex environments, or regulatory obligations.

- IG1 safeguards cover essentials such as:
  - Maintaining **inventory** of devices and software (Controls 1–2).
  - Secure **configuration** of systems and applications (Control 4).
  - Multi-factor **authentication** and least privilege for accounts and access (Controls 5–6).
  - **Patch** management and **vulnerability** management (Control 7).
  - **Backup** and tested data recovery, basic logging, anti-malware, and awareness training (Controls 8-14).

These are the **first controls to implement** when building or improving a security programme

→“**start with IG1**” principle

# Mapping CIS Controls to Other Frameworks

- CIS Controls v8.1 are mapped to and referenced by multiple legal, regulatory and policy frameworks (e.g. NIST CSF 2.0, ISO 27001, PCI DSS, SOC 2, CMMC).
- The addition of the **Govern** function and updated mappings in v8.1 improves consistency with NIST CSF 2.0 security functions.
- Organizations can **implement CIS Controls once** and use the mappings to demonstrate alignment across several governance and compliance regimes.

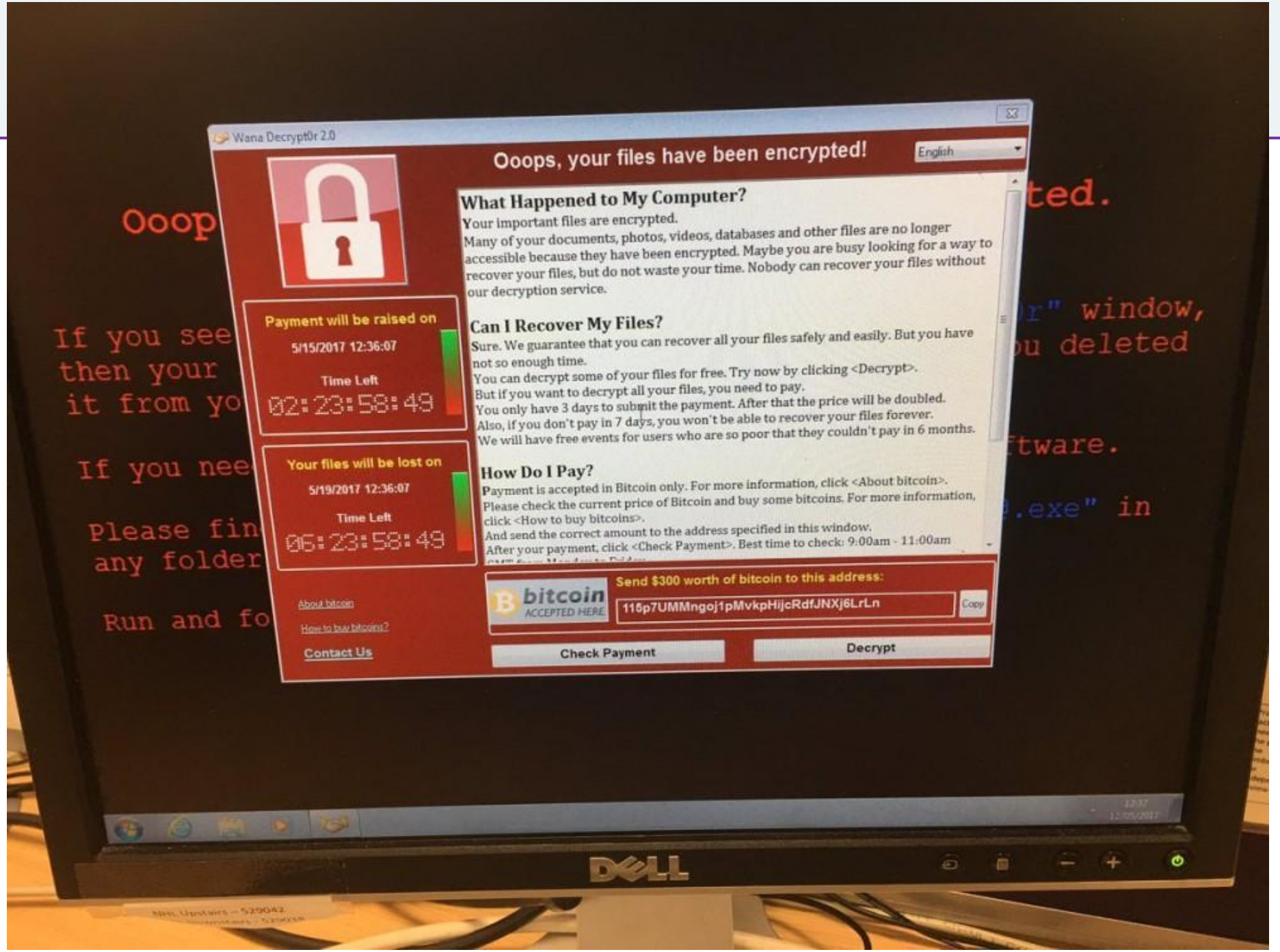
THEREFORE

CIS Controls Workflow:

1. Use CIS Controls as a **prioritized roadmap**: start with IG1 safeguards, then extend to IG2/IG3 depending on risk profile and regulatory drivers.
2. Treat each safeguard as a **measurable requirement** with evidence (design + operation) rather than a generic “good practice”.
3. Use Controls to structure security governance, then plug in other frameworks (NIST CSF, ISO 27001, Italian NCF) as overlays and mappings for reporting.

# Benefits of CIS Controls

- **Prioritized, actionable steps**
  clear, ordered safeguards that focus effort on the most impactful risk-reduction measures.
- **Attack-surface and risk reduction**
  directly target common attack vectors (unmanaged assets, misconfigurations, missing patches, weak access).
- **Essential cyber hygiene baseline**
  IG1 gives a realistic minimum programme for organizations of any size.
- **Efficient use of limited resources**
  helps allocate budget and staff to high-value controls first.
- **Multi-framework alignment**
  maps well to NIST CSF, NIST SP 800-53, ISO 27001, PCI DSS, HIPAA, etc., easing compliance.
- **Widely recognized “reasonable” standard**
  used globally and increasingly cited by regulators and insurers as evidence of due diligence.


Wana Decrypt0r 2.0
Ooops, your files have been encrypted!
English
What Happened to My Computer?
Your important files are encrypted.
Many of your documents, photos, videos, databases and other files are no longer accessible because they have been encrypted. Maybe you are busy looking for a way to recover your files, but do not waste your time. Nobody can recover your files without our decryption service.
Can I Recover My Files?
Sure. We guarantee that you can recover all your files safely and easily. But you have not so enough time.
You can decrypt some of your files for free. Try now by clicking <Decrypt>.
But if you want to decrypt all your files, you need to pay.
You only have 3 days to submit the payment. After that the price will be doubled.
Also, if you don't pay in 7 days, you won't be able to recover your files forever.
We will have free events for users who are so poor that they couldn't pay in 6 months.
How Do I Pay?
Payment is accepted in Bitcoin only. For more information, click <About bitcoin>.
Please check the current price of Bitcoin and buy some bitcoins. For more information, click <How to buy bitcoins>.
And send the correct amount to the address specified in this window.
After your payment, click <Check Payment>. Best time to check: 9:00am - 11:00am
Payment will be raised on
5/15/2017 12:36:07
Time Left
02:23:58:49
Your files will be lost on
5/19/2017 12:36:07
Time Left
06:23:58:49
About bitcoin
How to buy bitcoins?
Contact Us
bitcoin ACCEPTED HERE
Send $300 worth of bitcoin to this address:
115p7UMMngoj1pMvkpHijcRdfJNXj6LrLn
Copy
Check Payment
Decrypt
Ooop
If you see
then your
it from yo
If you nee
Please fin
any folder
Run and fo
ted.
r" window,
u deleted
ftware.
.exe" in
DELL

# Stop WannaCry

- You are the security team after WannaCry.
- We identified the risk and decided it must be treated. Now, what security controls do we actually implement?
- You have identified the main risk: **“Unpatched Windows systems could be exploited and cause widespread compromise.”**
- Management gives you **one month** to implement security measures.
- Which measures should be implemented to reduce this risk?
  - Formal patch management process
  - Asset inventory
  - Network segmentation
  - Vulnerability scanning
  - New company logo
  - Annual security presentation

# Stop WannaCry

The organization performs vulnerability scanning regularly.

What would convince an auditor that this control is actually implemented?

- “We have a vulnerability-management policy.”
- “The CISO says that scanning is performed.”
- “A vulnerability scanner is installed.”
- “Scan reports from the last six months.”
- “Evidence that some identified vulnerabilities were assigned and remediated.”
- “The vendor says the scanner works.”

C2: a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:
1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] access control policy that:
(a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
(b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and
2. Procedures to facilitate the implementation of the access control policy and the associated access controls;
b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the access control policy and procedures; and

| Control Identifier | Control (or Control Enhancement) Name | Control Text | Discussion | Related Controls |
|---|---|---|---|---|
| AC-1 | Policy and Procedures | a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:<br>1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] access control policy that:<br>(a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and<br>(b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and<br>2. Procedures to facilitate the implementation of the access control policy and the associated access controls;<br>b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the access control policy and procedures; and<br>c. Review and update the current access control:<br>1. Policy [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]; and<br>2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]. | Access control policy and procedures address the controls in the AC family that are implemented | IA-1, PM-9, PM-24, PS-8, SI-12 . |
| AC-2 | Account Management | a. Define and document the types of accounts allowed and specifically prohibited for use within the system;<br>b. Assign account managers;<br>c. Require [Assignment: organization-defined prerequisites and criteria] for group and role membership;<br>d. Specify:<br>1. Authorized users of the system;<br>2. Group and role membership; and<br>3. Access authorizations (i.e., privileges) and [Assignment: organization-defined attributes (as required)] for each account;<br>e. Require approvals by [Assignment: organization-defined personnel or roles] for requests to create accounts;<br>f. Create, enable, modify, disable, and remove accounts in accordance with [Assignment: organization-defined policy, procedures, prerequisites, and criteria];<br>g. Monitor the use of accounts;<br>h. Notify account managers and [Assignment: organization-defined personnel or roles] within:<br>1. [Assignment: organization-defined time period] when accounts are no longer required;<br>2. [Assignment: organization-defined time period] when users are terminated or transferred; and<br>3. [Assignment: organization-defined time period] when system usage or need-to-know changes for an individual;<br>i. Authorize access to the system based on:<br>1. A valid access authorization;<br>2. Intended system usage; and<br>3. [Assignment: organization-defined attributes (as required)]; | Examples of system account types include individual, shared, group, system, guest, anonymous, emergency, developer, temporary, and service. Identification of authorized system users and the specification of access privileges reflect the requirements in other controls in the security plan. Users requiring administrative privileges on system accounts receive additional scrutiny by organizational personnel responsible for approving such accounts and privileged access, including system owner, mission or business owner, senior agency information security officer, or senior agency official for privacy. Types of accounts that organizations may wish to prohibit due to increased risk include shared, group, emergency, anonymous, temporary, and guest accounts.<br>Where access involves personally identifiable information, security programs collaborate with the senior agency official for privacy to establish the specific conditions for group and role membership; specify authorized users, group and role membership, and access authorizations for each account; and create, adjust, or remove system accounts in accordance with organizational policies. Policies can include such information as account expiration dates or other factors that trigger the disabling of accounts. Organizations may choose to define access privileges or other attributes by account, type of account, or a combination of the two.<br>Examples of other attributes required for authorizing access include restrictions on time of day, day of week, and point of origin. In defining other system account attributes, organizations consider system-related requirements and mission/business requirements. Failure to consider these factors could affect system availability.<br>Temporary and emergency accounts are intended for short-term use. Organizations establish temporary accounts as part of normal account activation procedures when there is a need for short-term accounts without the demand for immediacy in account activation. Organizations establish emergency accounts in response to crisis situations and with the need for rapid account activation. Therefore, emergency account activation may bypass normal account | AC-3, AC-5, AC-6, AC-17, AC-18, AC-20, AC-24, AU-2, AU-12, CM-5, IA-2, IA-4, IA-5, I 8, MA-3, MA-5, PE-2, PL-4, PS-2, PS-4, PS-5, PS-7, PT-2, PT-3, SC-7, SC-12, SC-13, SC- 37. |

# Stop WannaCry: exercise (NIST SP 800-53)

| Control ID | Control Name | Control Text | Discussion | Related Control |
|---|---|---|---|---|
| CM-8 | System Component Inventory | a. Develop and document an inventory of system components that:<br>1. Accurately reflects the system;<br>2. Includes all components within the system;<br>3. Does not include duplicate accounting of components or components assigned to any other system;<br>4. Is at the level of granularity deemed necessary for tracking and reporting; and [...] | System components are discrete, identifiable information technology assets that include hardware, software, and firmware. [...] | CM-2, CM-7, CM-9, CM-10, CM-11, CM-13, CP-2, CP-9, MA-2, MA-6, PE-20, PL-9, PM-5, SA-4, SA-5, SI-2, SR-4. |

| **Risk** | **Security Objective** | **Implementation** | **Responsible Role** | **Priority** | **Evidence** | **Coverage** |
|---|---|---|---|---|---|---|
| Vulnerable or unmanaged Windows systems may be **unknown** to the organization and therefore **excluded from patching** and security monitoring. | Maintain an **accurate**, **complete**, and **up-to-date** inventory of systems and components. | - Maintain a centralized inventory of all Windows endpoints and servers, including *hostname, IP address, OS/version, owner, location, business criticality, and patch status*.<br><br>- **Automatically** discover assets and **regularly reconcile** the inventory with network scans and endpoint-management systems. | IT Asset Manager<br><br>Infrastructure Team | High | asset inventory, asset-discovery reports, reconciliation reports, endpoint-management records, inventory review records | **Partially covered** |

# End of lesson

# What about AI?

- AI systems introduce new assets and attack surfaces, including training data, models, prompts, inference interfaces, plugins, and model supply chains.
- AI failures can affect not only confidentiality, integrity, and availability, but also safety, fairness, privacy, transparency, and fundamental rights.
- Traditional cybersecurity controls remain necessary, but they do not fully address risks such as data poisoning, model extraction, prompt injection, adversarial examples, and unsafe model behavior.
- AI security frameworks therefore combine cybersecurity, privacy, safety, reliability, governance, and responsible-AI principles.

# Takeaways

- ✓ Cybersecurity governance requires more than isolated technical controls.
- ✓ Security frameworks provide structure and a common language for managing risk.
- ✓ Standards provide formal requirements that can be assessed or certified.
- ✓ Controls translate governance objectives into concrete safeguards.
- ✓ Best practices help organizations prioritize feasible and effective actions.
- ✓ Risk, business context, regulatory requirements, and available resources should guide framework selection.
- ✓ Profiles, baselines, tailoring, and implementation groups help adapt generic guidance to specific organizations.
- ✓ Continuous monitoring, assessment, auditing, learning, and improvement are essential.
- ✓ Cybersecurity responsibilities must be shared by leadership, technical staff, employees, suppliers, and other stakeholders.
- ✓ AI systems require extending traditional cybersecurity with governance, safety, privacy, fairness, reliability, and lifecycle-risk management.

# References


1. NIST. *The NIST Cybersecurity Framework 2.0*. NIST CSWP 29, 2024. https://doi.org/10.6028/NIST.CSWP.29
2. ISO/IEC. *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. https://www.iso.org/standard/27001
3. ISO/IEC. *ISO/IEC 27002:2022: Information security, cybersecurity and privacy protection — Information security controls*. https://www.iso.org/standard/75652.html
4. NIST. *Security and Privacy Controls for Information Systems and Organizations*. SP 800-53 Rev. 5. https://csrc.nist.gov/projects/risk-management/sp800-53-controls
5. NIST. *Control Baselines for Information Systems and Organizations*. SP 800-53B. https://csrc.nist.gov/projects/risk-management/sp800-53-controls/downloads
6. Center for Internet Security. *CIS Critical Security Controls v8.1*. https://www.cisecurity.org/controls/v8-1
7. CIS-Sapienza and CINI Cybersecurity National Lab. *Framework Nazionale per la Cybersecurity e la Data Protection*. https://www.cybersecurityframework.it/
8. OWASP. *Top 10 for Large Language Model Applications*. https://genai.owasp.org/llm-top-10/
9. European Union. *Regulation (EU) 2024/1689 — Artificial Intelligence Act*. https://eur-lex.europa.eu/eli/reg/2024/1689/oj